

Audit de sécurité

Enseignante : Mme Maha Charfeddine
Maitre de conférences en informatique ENIS

ISO 27001 LI/LA, ISO 42001 LI, ISO 21500 LPM, PECB Instructor
IEEE I-PROTECT event chair

Plan

- Introduction au système de management de la sécurité de l'information (SMSI) et à ISO/IEC 27001
- Principes d'audit, préparation et initiation d'un audit
- Activités d'audit sur site
- Clôture de l'audit

Chapitre 1 : Introduction au système de management de la sécurité de l'information (SMSI) et à ISO/IEC 27001

- Section1 : Objectifs et structure de la formation
- Section2 : Normes et cadres réglementaires
- Section3 : Processus de certification
- Section4 : Concepts et principes fondamentaux de la sécurité de l'information
- Section5 : Système de management de la sécurité de l'information (SMSI)

Qu'est-ce que l'ISO ?

- L'ISO est une organisation internationale regroupant des organismes nationaux de normalisation de plus de 160 pays.
- Les résultats finaux des travaux de l'ISO sont publiés en tant que normes internationales.
- L'ISO a publié plus de 24 000 normes depuis 1947.



La famille de normes ISO/IEC 27000

Vocabulaire	ISO/IEC 27000 Vue d'ensemble et vocabulaire			
Exigences	ISO/IEC 27006 Organismes fournissant l'audit et la certification de SMSI	ISO/IEC 27001 Système de management de la sécurité de l'information		ISO/IEC 27701 Système de management de la protection de la vie privée
Lignes directrices	ISO/IEC 27002 Mesures de sécurité de l'information	ISO/IEC 27003 SMSI	ISO/IEC 27004 Surveillance, mesure, analyse et évaluation	ISO/IEC 27005 Gestion des risques liés à la sécurité de l'information
Lignes directrices propres à un secteur	ISO/IEC 27011 Organismes de télécommunications	ISO 27799 Informatique de santé		Autres normes de la famille ISO/IEC 27000

19/02/2026

Dr Maha Charfeddine

5

ISO/IEC 27001

- Cette norme spécifie les exigences pour la mise en œuvre d'un SMSI (articles 4 à 10).
- Les exigences (articles) sont écrites en utilisant le verbe impératif « doit ».
- L'Annexe A présente 4 articles et 93 mesures de sécurité de l'information
- Les organismes peuvent obtenir une certification conformément à cette norme.



19/02/2026

Dr Maha Charfeddine

6

ISO/IEC 27002

- La norme fournit une liste de mesures génériques de la sécurité de l'information et des conseils pour leur mise en œuvre.
- Les articles sont exprimés par l'expression « il convient que ».
- Cette norme ne se prête pas à des fins de certification.



19/02/2026

Dr Maha Charfeddine

7

ISO/IEC 27701

- Cette norme est une extension des normes ISO/IEC 27001 et ISO/IEC 27002 pour la gestion des informations sur la vie privée.
- Elle précise les exigences et fournit des lignes directrices pour un PIMS.
- Les exigences de la norme (articles) sont rédigées en utilisant le verbe impératif « doit ».
- Les organismes peuvent obtenir une certification conformément à cette norme.



19/02/2026

Dr Maha Charfeddine

8

ISO/IEC 27010+

Parmi les normes de la famille ISO/IEC 27000, ISO/IEC 27010 et les suivantes sont réservées aux normes sectorielles.

- **Pour les industries :**
 - ▷ Télécommunications
 - ▷ Santé
 - ▷ Finances et assurance
- **Pour les secteurs spécifiques liés à la sécurité de l'information :**
 - ▷ Sécurité des applications
 - ▷ Cybersécurité
 - ▷ Gestion des incidents de sécurité
 - ▷ Protection de la vie privée



19/02/2026

Dr Maha Charfeddine

9

Avantages d'ISO/IEC 27001



1. Amélioration de la sécurité
2. Bonne gouvernance
3. Reconnaissance internationale accrue
4. Satisfaction accrue de la clientèle
5. Avantage concurrentiel

19/02/2026

Dr Maha Charfeddine

10

Conformité légale et réglementaire

- L'organisme doit se conformer aux lois et réglementations applicables.
- Dans la plupart des pays, la mise en œuvre d'une norme ISO est une décision volontaire de l'organisme, pas une exigence légale.
- Dans tous les cas, les lois prévalent sur les normes.

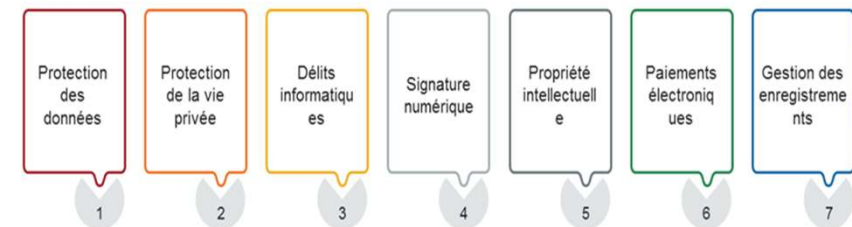
ISO/IEC 27001 peut être utilisée pour se conformer à diverses lois et réglementations.

19/02/2026

Dr Maha Charfeddine

11

Conformité légale et réglementaire



19/02/2026

Dr Maha Charfeddine

12

Quiz 1

19/02/2026

Dr Maha Charfeddine

13

1) Que spécifie la norme ISO/IEC 27001 ?

- a. Exigences pour les organismes certifiant un système de management de la sécurité de l'information
- b. Exigences pour la mise en œuvre d'un système de management de la sécurité de l'information
- c. Lignes directrices pour l'audit d'un système de management de la sécurité de l'information

2) Les organismes peuvent obtenir une certification conformément à la norme ISO/IEC 27002 s'ils mettent en œuvre toutes les mesures de sécurité de l'information.

- a. Vrai
- b. Faux

3) La mise en œuvre d'ISO/IEC 27001 est une exigence légale dans la plupart des pays.

- a. Vrai
- b. Faux

19/02/2026

Dr Maha Charfeddine

14

3) Quel est l'objectif des lois régissant les droits de propriété intellectuelle ?

- a. Protéger certains actifs incorporels
- b. Assurer que certains actifs sont revus régulièrement
- c. Fournir des rapports de gestion des actifs à des fins légales

4) Lequel des énoncés suivants est un des objectifs de la Politique de protection de la vie privée ?

- a. Augmenter la sensibilisation aux exigences légales concernant la protection de l'information personnelle
- b. Augmenter la sensibilisation aux cybercrimes visant le réseau informatique d'un organisme
- c. Augmenter la sensibilisation concernant la validité des signatures numériques dans les documents électroniques

19/02/2026

Dr Maha Charfeddine

15

Processus de certification

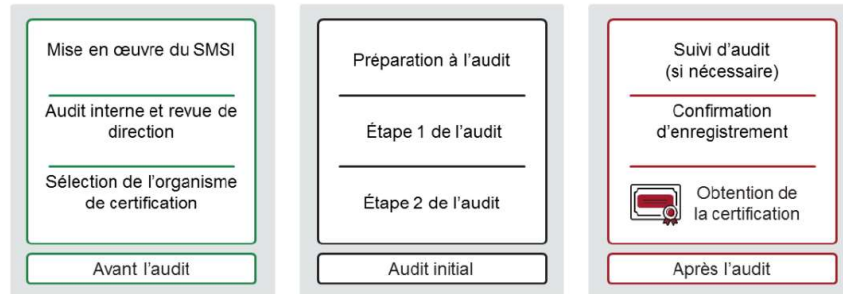
- Processus de certification
- Programme de certification
- Organismes d'accréditation
- Organismes de certification

19/02/2026

Dr Maha Charfeddine

16

Processus de certification



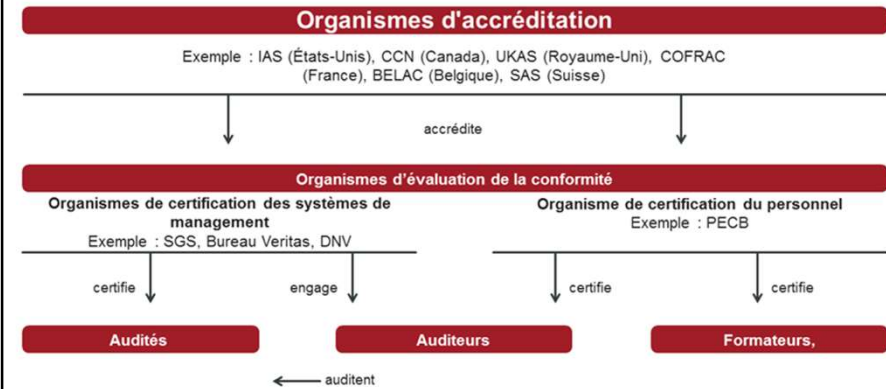
Note : Après l'obtention de la certification, un audit de surveillance sera mené afin d'assurer l'amélioration continue.

19/02/2026

Dr Maha Charfeddine

17

Programme de certification



19/02/2026

Dr Maha Charfeddine

18

Organismes d'accréditation

- Un organisme d'accréditation est un organisme indépendant qui fait autorité et qui vérifie si un organisme d'évaluation de la conformité répond aux critères établis et s'il est compétent pour effectuer des tâches d'évaluation de la conformité.
- Les organismes d'accréditation tirent généralement leur autorité du gouvernement.



19/02/2026

Dr Maha Charfeddine

19

Organismes de certification

- Les organismes de certification certifient des systèmes de management, des personnes, des produits, des processus et des services.
- Les organismes de certification sont toujours des organismes d'évaluation de la conformité tiers et impartiaux.



19/02/2026

Dr Maha Charfeddine

20

Quiz 2

19/02/2026

Dr Maha Charfeddine

21

1. Quand l'audit de surveillance est-il mené ?

- A. Après la réalisation de l'étape2 de l'audit
- B. Après la réalisation du suivi d'audit
- C. Après l'obtention de la certification

2. ISO réalise des activités d'accréditation et de certification.

- A. Vrai
- B. Faux

3. Laquelle des affirmations suivantes est vraie ?

- A. Les organismes de certification sont accrédités par les organismes d'accréditation
- B. Les organismes de certification sont certifiés par les organismes d'accréditation
- C. Les organismes de certification sont embauchés par les organismes d'accréditation

19/02/2026

Dr Maha Charfeddine

22

4. L'organisme tiers qui évalue la conformité des systèmes de management est :

- A. Une norme internationale
- B. Un organisme d'accréditation
- C. Un organisme de certification

5. Votre Marché est une société de recherche marketing qui aide ses clients à établir quels produits et services sont en demande. La société évalue présentement l'efficacité de ses mesures de sécurité de l'information par un audit du SMSI. Qu'est-ce que Votre Marché dans ce cas ?

- A. Un organisme d'accréditation
- B. Un organisme de certification
- C. Un audité

19/02/2026

Dr Maha Charfeddine

23

Section 4

Concepts et principes fondamentaux de la sécurité de l'information

- Information et actif
- Sécurité de l'information
- Confidentialité, intégrité et disponibilité
- Vulnérabilité, menace et impact
- Risque de sécurité de l'information
- Mesures et objectifs des mesures de sécurité
- Classification des mesures de sécurité

19/02/2026

Dr Maha Charfeddine

24

Information et actif

ISO 9000, article 3.8.2 et ISO 55000, article 3.2.1

Information : données porteuses de sens

Actif : item, chose ou entité qui a une valeur potentielle ou réelle pour un organisme

Il existe plusieurs types d'actifs, par exemple :

- Information
- Logiciel, comme un programme d'ordinateur
- Actifs physiques, comme les ordinateurs
- Services
- Personnes et leurs qualifications et compétences
- Actifs intangibles, comme la réputation et l'image



19/02/2026

Dr Maha Charfeddine

25

Document, spécification, enregistrement

ISO 9000, articles 3.8.5, 3.8.7 et 3.8.10

Document

support d'information et l'information qu'il contient

Spécification

document formulant des exigences

Enregistrement

document faisant état de résultats obtenus ou apportant la preuve de la réalisation d'une activité

19/02/2026

Dr Maha Charfeddine

26

Sécurité de l'information

- ISO/IEC 27000, article 3.28, définit la sécurité de l'information comme étant la « protection de la confidentialité, de l'intégrité et de la disponibilité de l'information ».
- La sécurité de l'information détermine quelles informations doivent être protégées, la raison pour laquelle elles doivent l'être, comment les protéger et de quoi il faut les protéger.
- En protégeant l'organisme contre les menaces et les vulnérabilités, la sécurité de l'information réduit le niveau de risques et leur impact sur l'organisme.
- La sécurité de l'information couvre les informations de toute nature, imprimées ou manuscrites, transmises par e-mail ou sur un site Web, mentionnées au cours d'une conversation, etc.



19/02/2026

Dr Maha Charfeddine

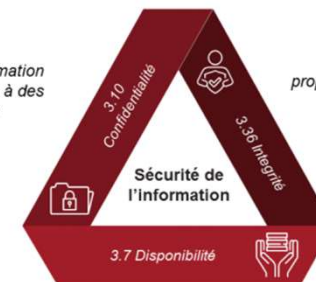
27

Confidentialité, intégrité et disponibilité

ISO/IEC 27000, articles 3.7, 3.10 et 3.36

propriété selon laquelle l'information n'est pas diffusée ni divulguée à des personnes, des entités ou des processus non autorisés

propriété d'exactitude et de complétude



propriété d'être accessible et utilisable à la demande par une entité autorisée

19/02/2026

Dr Maha Charfeddine

28

Confidentialité

- La confidentialité exige que seuls les utilisateurs autorisés aient accès aux données sensibles et confidentielles.
- Certaines des pratiques utilisées pour assurer la confidentialité sont les suivantes :
 - ▷ Processus d'authentification, qui requiert un identifiant et un mot de passe pour accéder à des données confidentielles ;
 - ▷ Méthodes de sécurité pour assurer l'autorisation du visiteur ;
 - ▷ Contrôles d'accès qui permettent aux utilisateurs de rester dans les limites de leur rôle.



19/02/2026

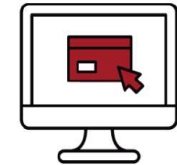
Dr Maha Charfeddine

29

Intégrité

Le concept d'intégrité consiste à :

- Veiller à ce que les informations ne soient pas modifiées lorsqu'elles sont stockées ou en transit
- S'assurer que seules les modifications autorisées sont apportées
- S'assurer que les données sont exactes, authentiques et protégées contre tout accès non autorisé, afin que les utilisateurs puissent se fier à la justesse de l'information lors du traitement



19/02/2026

Dr Maha Charfeddine

30

Disponibilité

La disponibilité de l'information est cruciale pour la sécurité de l'information moderne.

C'est l'information qui est accessible :

- comme requis
- quand c'est requis
- là où c'est requis
- pour qui c'est requis

Les responsables de la sécurité de l'information font habituellement face à trois défis :

- Déné de service (DoS) à la suite d'attaques intentionnelles (p. ex. lorsqu'un programmeur n'est pas au courant d'un défaut qui pourrait endommager le logiciel en raison d'une entrée spécifique et inattendue)
- Perte des capacités de protection des systèmes d'information en raison de catastrophes naturelles ou d'activités humaines
- Pannes d'équipement



19/02/2026

Dr Maha Charfeddine

31

Vulnérabilité

- ISO/IEC 27000, article 3.77, définit la vulnérabilité comme la « faille dans un actif ou dans une mesure de sécurité qui peut être exploitée par une ou plusieurs menaces. »
- Les vulnérabilités qui n'ont pas de menaces correspondantes peuvent ne pas nécessiter de mesures, mais devraient être reconnues et régulièrement surveillées.
- Les mesures qui ne sont pas mises en œuvre correctement ou qui fonctionnent mal pourraient devenir des vulnérabilités.



19/02/2026

Dr Maha Charfeddine

32

Types de vulnérabilités

ISO/IEC 27005, Annexe D.1

Types	Exemples de vulnérabilités
Matériel	Absence de programmes de remplacement périodique
Logiciel	Interface utilisateur compliquée
Réseau	Point de défaillance unique
Personnel	Travail non surveillé d'une équipe extérieure ou de l'équipe d'entretien
Site	Emplacement situé dans une zone sujette aux inondations
Organisme	Absence de responsabilités en sécurité de l'information dans les descriptions de postes

19/02/2026

Dr Maha Charfeddine

33

Types de vulnérabilités

ISO/IEC 27005, Annexe D.1

Types	Exemples de vulnérabilités
Matériel	Maintenance insuffisante/mauvaise installation des supports de stockage Absence de programmes de remplacement périodique
Logiciel	Tests de logiciel absents ou insuffisants Interface utilisateur compliquée
Réseau	Voies de communication non protégées Point de défaillance unique
Personnel	Formation insuffisante à la sécurité Travail non surveillé d'une équipe extérieure ou de l'équipe d'entretien
Site	Réseau électrique instable Emplacement situé dans une zone sujette aux inondations
Organisme	Absence de bonne attribution des responsabilités en sécurité de l'information Absence de responsabilités en sécurité de l'information dans les descriptions de postes

19/02/2026

Dr Maha Charfeddine

34

Menaces

ISO/IEC 27000, article 3.74 et ISO/IEC 27005, article 8.2.3

Menace : cause potentielle d'un incident indésirable, qui peut nuire à un système ou à un organisme

Une menace est susceptible d'endommager les actifs tels que des informations, des processus et des systèmes et, par conséquent, des organismes.

Les menaces peuvent être d'origine naturelle ou humaine et peuvent être accidentelles ou délibérées. Il convient d'identifier les sources de menace à la fois accidentelles et délibérées.



19/02/2026

Dr Maha Charfeddine

35

Types de menaces

ISO/IEC 27005, Annexe C

Types	Menaces
Dommages physiques	Dégât des eaux
Catastrophes naturelles	Inondation
Perte de services essentiels	Perte de la source d'alimentation en électricité
Perturbation due à des rayonnements	Rayonnements thermiques
Compromission d'informations	Vol de supports ou de documents
Défaillances techniques	Dysfonctionnement du logiciel
Actions non autorisées	Corruption de données
Compromission des fonctions	Contrefaçon de droits

19/02/2026

Dr Maha Charfeddine

36

Types de menaces

ISO/IEC 27005, Annexe C

Types	Menaces
Dommages physiques	Incendie
	Dégât des eaux
Catastrophes naturelles	Phénomène volcanique
	Inondation
Perte de services essentiels	Panne du système de climatisation ou d'alimentation en eau
	Perte de la source d'alimentation en électricité
Perturbation due à des rayonnements	Rayonnements électromagnétiques
	Rayonnements thermiques
Compromission d'informations	Piégeage de matériel
	Vol de supports ou de documents
Défaillances techniques	Panne de matériel
	Dysfonctionnement du logiciel
Actions non autorisées	Utilisation non autorisée du matériel
	Corruption de données
Compromission des fonctions	Erreur d'utilisation
	Contrefaçon de droits

19/02/2026

Dr Maha Charfeddine

37

Relation : Vulnérabilité et menace

Exemples

Vulnérabilités	Menaces
Entrepôt non protégé et sans surveillance	
Procédures compliquées de traitement des données	
Pas de séparation des tâches	
Données non chiffrées	
Utilisation de logiciels piratés	
Pas de revue des droits d'accès	
Pas de procédures de sauvegarde	

19/02/2026

Dr Maha Charfeddine

38

Relation : Vulnérabilité et menace

Exemples

Vulnérabilités	Menaces
Entrepôt non protégé et sans surveillance	Vol
Procédures compliquées de traitement des données	Erreur d'entrée des données par le personnel
Pas de séparation des tâches	Fraude, utilisation non autorisée d'un système
Données non chiffrées	Vol de données
Utilisation de logiciels piratés	virus
Pas de revue des droits d'accès	Accès non autorisé par des personnes qui ont quitté l'organisme
Pas de procédures de sauvegarde	Perte d'information

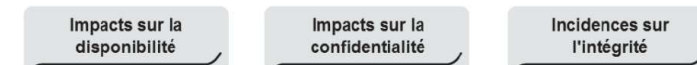
19/02/2026

Dr Maha Charfeddine

39

Impact

Exemples



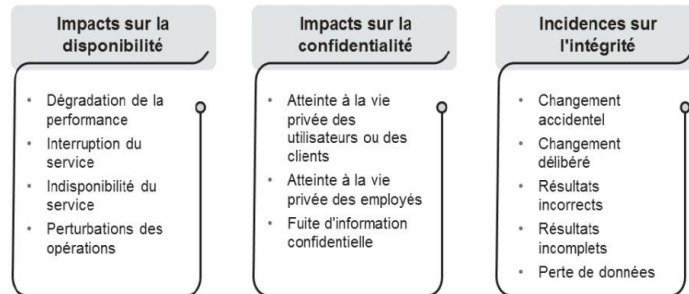
19/02/2026

Dr Maha Charfeddine

40

Impact

Exemples



19/02/2026

Dr Maha Charfeddine

41

Vulnérabilité, menace et impact

Exemples

Vulnérabilité	Menace	Impact
Entrepôt non surveillé	Vol d'équipement	
Sensibilité à l'humidité	Corrosion	
Interface utilisateur compliquée	Erreur d'entrée de données	
Ligne de communication non protégée	Écoute électronique	
Transfert des mots de passe en clair	Hacker	
Processus de gestion de la documentation inexistant	Corruption de données	

19/02/2026

Dr Maha Charfeddine

42

Vulnérabilité, menace et impact

Exemples

Vulnérabilité	Menace	Impact
Entrepôt non surveillé	Vol d'équipement	Pertes financières
Sensibilité à l'humidité	Corrosion	Panne de matériel
Interface utilisateur compliquée	Erreur d'entrée de données	Base de données corrompue
Ligne de communication non protégée	Écoute électronique	Interception des communications
Transfert des mots de passe en clair	Hacker	Vol de données
Processus de gestion de la documentation inexistant	Corruption de données	Perte de disponibilité et d'intégrité de l'information

19/02/2026

Dr Maha Charfeddine

43

Risque de sécurité de l'information

ISO/IEC 27000, article 3.61

- Note 6 à l'article: Le risque lié à la sécurité de l'information est associé à la possibilité que des menaces exploitent les vulnérabilités d'un actif ou d'un groupe d'actifs informationnels et nuisent donc à un organisme.*
- Note 4 à l'article: Un risque est souvent exprimé en termes de combinaison des conséquences d'un événement (incluant des changements de circonstances) et de sa « vraisemblance ».*



19/02/2026

Dr Maha Charfeddine

44

Risque de sécurité de l'information

Exemple 1 : Le risque obtenu est mesuré sur une échelle de 0 à 8 :

- risque faible: 0 à 2;
- risque moyen: 3 à 5;
- risque élevé: 6 à 8

	Vraisemblance d'un scénario d'incident	Très faible (Très peu probable)	Faible (Peu probable)	Moyenne (Possible)	Élevée (Probable)	Très élevée (Fréquente)
Impact sur l'activité	Très faible	0	1	2	3	4
	Faible	1	2	3	4	5
	Moyen	2	3	4	5	6
	Élevé	3	4	5	6	7
	Très élevé	4	5	6	7	8

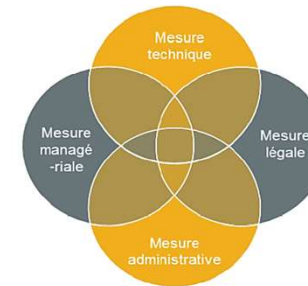
Exemple 2 : Le risque obtenu est mesuré sur une échelle de 1 à 25

Probabilité/Impact	Négligeable ou nul (1)	Mineur (2)	Modéré (3)	Majeur (4)	Critique (5)
Très rare (1)	1 - Très faible	2 - Très faible	3 - Faible	4 - Faible	5 - Moyen
Peu probable (2)	2 - Très faible	4 - Faible	6 - Moyen	8 - Moyen	10 - Moyen
Possible (3)	3 - Faible	6 - Moyen	9 - Moyen	12 - Élevé	15 - Élevé
Très probable (4)	4 - Faible	8 - Moyen	12 - Élevé	16 - Élevé	20 - Très élevé
Presque certain (5)	5 - Moyen	10 - Moyen	15 - Élevé	20 - Très élevé	25 - Très élevé

ISO/IEC 27000, article 3.14 Mesure de sécurité *mesure qui modifie un risque*

Classification des mesures de sécurité

Classification par type



Mesure technique

Mesure liée à l'utilisation de mesures techniques ou technologies comme les pare-feu, les systèmes d'alarme, les caméras de surveillance, etc.

Mesure légale

Mesure liée à l'application d'une législation, des exigences réglementaires ou des obligations contractuelles.

Mesure administrative

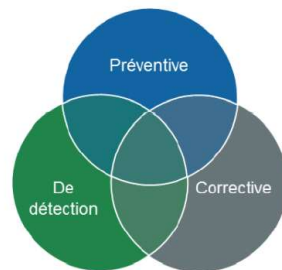
Mesure liée à la structure organisationnelle comme la séparation des tâches, la rotation des postes, les descriptions de tâches, les processus d'approbation, etc.

Mesure managériale

Mesure liée à la gestion du personnel, incluant la formation et le coaching des employés, les revues de direction et les audits, etc.

Classification des mesures de sécurité

Classification par fonction



Mesure préventive

Décourager ou prévenir l'apparition des incidents

Mesure de détection

Rechercher, détecter et identifier les incidents

Mesure corrective

Résoudre les incidents détectés et en prévenir la récurrence

19/02/2026

Dr Maha Charfeddine

47

Classification des mesures de sécurité

Exemples

Mesures préventives

- Publier une politique de sécurité de l'information
- Signer un accord de confidentialité
- Embauche de personnel qualifié seulement
- Identification des risques provenant des tiers
- Assignment des tâches

Mesures détectives

- Surveiller et revoir les services tiers
- Surveiller les ressources utilisées par les systèmes
- Déclenchement d'alarmes, p. ex. en cas d'incendie
- Revue des droits d'accès utilisateurs
- Analyser les journaux d'audit

Mesures correctives

- Enquête technico-légale (forensique) à la suite d'un incident de sécurité
- Activation du plan de continuité d'activité après le déclenchement d'un sinistre
- Installation de correctifs après l'identification de vulnérabilités techniques

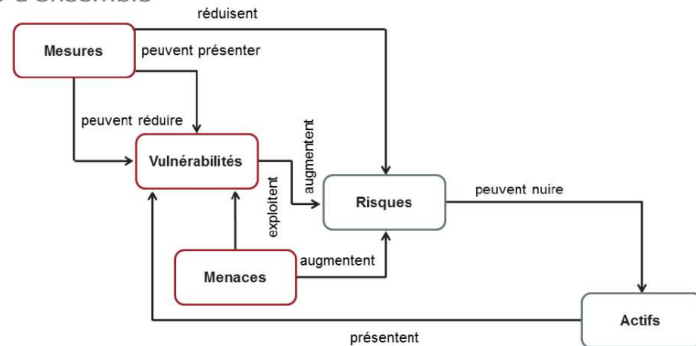
19/02/2026

Dr Maha Charfeddine

48

Relations entre les aspects de la sécurité de l'information

Vue d'ensemble



19/02/2026

Dr Maha Charfeddine

49

Quiz 3 & Exercice « Types de Mesures »

19/02/2026

Dr Maha Charfeddine

50

Quelle est la différence entre un document, une spécification et un enregistrement ?

- A. Une spécification est un document qui formule des exigences alors qu'un enregistrement est un document faisant état de résultats obtenus
- B. Une spécification est un support d'information et l'information qu'il contient alors qu'un enregistrement est un document qui formule des exigences
- C. Une spécification et un enregistrement sont tous les deux des documents et sont donc interchangeables

Un ancien employé de la Société A a accédé sans autorisation aux données sensibles de la société. Qu'est-ce que ça représente ?

- A. Une menace susceptible d'endommager les actifs tels que des informations ou des systèmes
- B. Une vulnérabilité du système de surveillance de l'organisme, mais qui n'a pas de menace correspondante
- C. Une mesure de sécurité incorrectement mise en œuvre par l'organisme, sans qu'elle représente une vulnérabilité

Lequel des principes suivants un organisme respecte-t-il s'il veille à ce que seuls les utilisateurs autorisés aient accès à ses données sensibles ?

- A. Confidentialité
- B. Intégrité
- C. Disponibilité

19/02/2026

Dr Maha Charfeddine

51

Un organisme a clairement défini les procédures de sécurité et utilise un logiciel de contrôle d'accès afin d'éviter tout accès non autorisé du personnel à ses données confidentielles. Quelle est la fonction de ces mesures de sécurité ?

- A. Prévenir l'apparition des incidents
- B. Corriger les erreurs résultant d'un problème
- C. Signaler l'apparition d'un acte malveillant

À quelle classification des mesures de sécurité appartient la mise en œuvre des correctifs après l'identification des vulnérabilités du système ?

- A. Mesure de fonction préventive et de type managérial
- B. Mesure de fonction corrective et de type technique
- C. Mesure de fonction de détection et de type administratif

19/02/2026

Dr Maha Charfeddine

52

Exercice : Types des mesures de sécurité

Pour chacune des mesures suivantes, indiquez si elle est utilisée comme mesure **préventive**, **corrective** et/ou de **détection** ; précisez si la mesure est une **mesure administrative**, **technique**, **managériale** ou **légale**.

Exemple 1 : L'installation d'une clôture métallique autour du site de l'organisme.

- C'est une mesure **préventive** qui aidera à sécuriser le site de l'organisme contre l'accès physique non autorisé. L'installation d'une clôture métallique est une mesure **technique** qui implique une installation matérielle.

Exemple 2 : Attribution des responsabilités en matière de sécurité de l'information à chaque membre de l'organisme

Exemple 3 : Mise en place d'un système d'alarme incendie

Exemple 4 : Cryptage des communications électroniques

Exemple 4 : Enquête technico-légale sur un incident de sécurité :

19/02/2026

Dr Maha Charfeddine

53

Système de management de la sécurité de l'information (SMSI)

- Définition de système de management
- Définition de SMSI
- Approche processus
- Mise en œuvre du SMSI
- Vue d'ensemble – articles 4 à 10
- Vue d'ensemble – Annexe A
- Déclaration d'applicabilité

19/02/2026

Dr Maha Charfeddine

54

Définition de système de management

ISO/IEC 27000, article 3.41

ensemble d'éléments corrélés ou interactifs d'un organisme visant à établir des politiques, des objectifs et des processus permettant d'atteindre ces objectifs

Note 1 à l'article:

Un système de management peut recouvrir une ou plusieurs disciplines.

Note 2 à l'article:

Les éléments du système comprennent la structure de l'organisme, les rôles et responsabilités, la planification et les opérations.

Note 3 à l'article:

Le domaine d'un système de management peut comprendre l'organisme dans son ensemble, certaines de ses fonctions spécifiques et identifiées, certaines de ses sections spécifiques et identifiées, ou une ou plusieurs fonctions au sein d'un groupe d'organismes.

19/02/2026

Dr Maha Charfeddine

55

Normes de systèmes de management

Les organismes peuvent être certifiés selon les normes principales suivantes :



19/02/2026

Dr Maha Charfeddine

56

Systèmes de management intégrés

Structure commune des normes d'ISO

Exigences	ISO 9001:2015	ISO 14001:2015	ISO/IEC 27001:2022	ISO 22301:2019	ISO 22000:2018
Leadership et engagement	5.1	5.1	5.1	5.1	5.1
Politique	5.2	5.2	5.2	5.2	5.2
Objectifs	6.2	6.2	6.2	6.2	6.2
Informations documentées	7.5	7.5	7.5	7.5	7.6
Audit interne	9.2	9.2	9.2	9.2	9.2
Revue de direction	9.3	9.3	9.3	9.3	9.3
Amélioration continue	10.3	10.3	10.1	10.2	10.3

Systèmes de management intégrés

Il y a plusieurs bonnes raisons pour l'intégration, notamment :

- Harmoniser et optimiser les pratiques
- Formaliser les systèmes informels
- Réduire la duplication et donc les coûts
- Réduire les risques et augmenter la rentabilité
- Se concentrer sur les objectifs de l'entreprise
- Créer et maintenir la cohérence
- Améliorer la communication

19/02/2026

Dr Maha Charfeddine

58

Définition de SMSI

ISO/IEC 27000, article 4.2.1

Un SMSI se compose des politiques, procédures, lignes directrices et des ressources et activités associées, gérées collectivement par un organisme dans le but de protéger ses actifs informationnels.

Un **SMSI** est une approche systématique pour :



la **sécurité de l'information** d'une organisation pour atteindre des objectifs métier.

Cette approche se fonde sur l'appréciation du risque et sur les niveaux d'acceptation du risque définis par l'organisme pour traiter et gérer efficacement les risques.

Définition de SMSI

Système de Management de la sécurité de l'information



Pour un organisme, la mise en œuvre d'un SMSI permettra d'instaurer une culture d'apprentissage et d'amélioration continus en prenant en compte la sécurité de l'information dans toutes les procédures, politiques et activités.



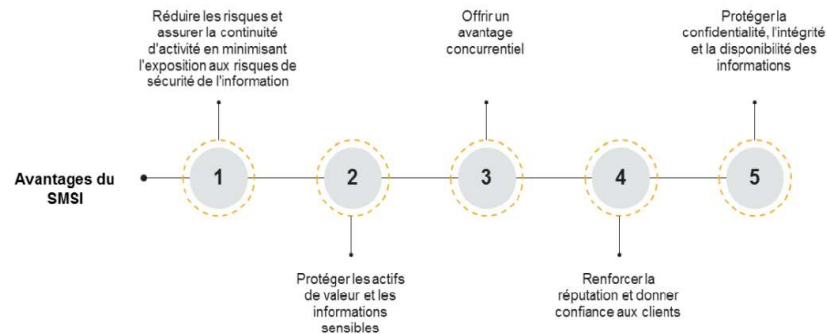
Le SMSI présente les mesures à mettre en œuvre par un organisme qui entend réduire les risques de sécurité de l'information et accroître la sensibilisation à la sécurité de l'information au sein de l'organisme.

19/02/2026

Dr Maha Charfeddine

60

Importance du SMSI



19/02/2026

Dr Maha Charfeddine

61

PDCA

• **Plan** : La construction de ce SMSI est imaginée, planifiée, préparée de manière à tenir compte et anticiper l'ensemble des risques relatifs à la sécurité de l'information.

• **Do** : Des contrôles opérationnels sont mis en oeuvre pour créer le SMSI et le rendre fonctionnel dans l'environnement de l'organisme.

• **Check** : Les contrôles mis en place sont régulièrement suivies, évaluées, mesurées de façon à être améliorés.

• **Act** : Les actions de corrections sont apportées rapidement de manière à atteindre les objectifs prévus.



19/02/2026

Dr Maha Charfeddine

62

Etude du cas de FinSecure

- FinSecure est une entreprise spécialisée dans les services financiers, offrant des solutions de gestion bancaire et de transactions électroniques.
- FinSecure propose plusieurs types de services essentiels dans le secteur financier**, notamment :
 - Gestion bancaire
 - Transactions électroniques

Dans un secteur où la sécurité de l'information est déterminante, l'entreprise doit garantir **l'intégrité, la confidentialité et la disponibilité des données financières de ses clients.**

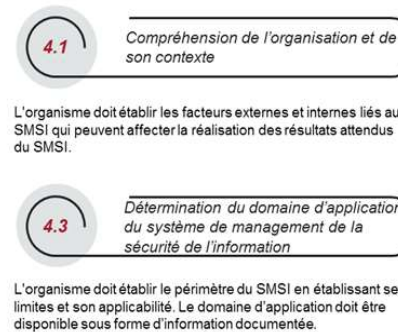
19/02/2026

Dr Maha Charfeddine

63

Contexte de l'organisation

ISO/IEC 27001, article 4



19/02/2026

Dr Maha Charfeddine

64

Contexte de l'organisation

ISO/IEC 27001, article 4

4.1 Compréhension de l'organisation et de son contexte

FinSecure analyse son environnement interne et externe :

- Facteurs internes :
- Facteurs externes :

Résultat : FinSecure identifie que sa croissance rapide et la réglementation renforcée nécessitent un renforcement de la sécurité de l'information

4.2 Compréhension des besoins et attentes des parties intéressées

L'entreprise identifie les parties intéressées et leurs exigences en matière de sécurité :

- Clients → Attendent une protection stricte de leurs données financières.
- Régulateurs → Exigent une conformité avec le RGPD/loi 2004 Tunisie et la protection des données/transactions bancaires PCI-DSS.
-
-

Résultat : FinSecure détermine qu'elle doit mettre en place un chiffrement avancé des données et renforcer la sensibilisation

19/02/2026

Dr Maha Charfeddine

65

Contexte de l'organisation

ISO/IEC 27001, article 4

4.1 Compréhension de l'organisation et de son contexte

FinSecure analyse son environnement interne et externe :

- Facteurs internes : Volume croissant de données sensibles clients
- Facteurs externes : Réglementations financières strictes (RGPD, PCI-DSS), menaces cybercriminelles en augmentation, exigences des partenaires commerciaux.

Résultat : FinSecure identifie que sa croissance rapide et la réglementation renforcée nécessitent un renforcement de la sécurité de l'information.

4.2 Compréhension des besoins et attentes des parties intéressées

L'entreprise identifie les parties intéressées et leurs exigences en matière de sécurité :

- Clients → Attendent une protection stricte de leurs données financières.
- Régulateurs → Exigent une conformité avec le RGPD/loi 2004 Tunisie et la protection des données/transactions bancaires PCI-DSS.
- Actionnaires → Souhaitent éviter tout risque réputationnel lié à une fuite de données.
- Employés → Besoin d'une formation sur la cybersécurité et d'outils sécurisés.

Résultat : FinSecure détermine qu'elle doit mettre en place un chiffrement avancé des données et renforcer la sensibilisation

19/02/2026

Dr Maha Charfeddine

66

Définir le périmètre du SMSI et les exclusions

Les limites organisationnelles du périmètre peuvent inclure :



Note Toute exclusion faite dans le périmètre doit être justifiée.

19/02/2026

Dr Maha Charfeddine

67

Contexte de l'organisation

ISO/IEC 27001, article 4

4.3 Détermination du domaine d'application du SMSI

FinSecure définit le périmètre de son SMSI :

- Inclus : Systèmes informatiques internes, bases de données clients, serveurs cloud, échanges de données avec les banques.
- Exclus :

Résultat : La portée du SMSI est clairement définie, et un document officiel est créé pour préciser ce périmètre.

4.4 Système de management de la sécurité de l'information :

FinSecure s'engage à :

- Établir un SMSI → Définition deset mise en place d'un responsable de la sécurité (.....).
- Mettre en œuvre le SMSI → Basé sur une étude: Déploiement d'un pare-feu, protection des bases de données, plan de gestion des incidents....
- Maintenir et améliorer → Réalisation réguliers, mise à jour continue des processus,...

Résultat : L'entreprise suit un processus d'amélioration continue pour garantir la sécurité de l'information.

19/02/2026

Dr Maha Charfeddine

68

Contexte de l'organisation

ISO/IEC 27001, article 4

4.3 Détermination du domaine d'application du SMSI

FinSecure définit le périmètre de son SMSI :

- **Inclus** : Systèmes informatiques internes, bases de données clients, serveurs cloud, échanges de données avec les banques.

- **Exclus** : Équipements personnels des employés

Résultat : La portée du SMSI est clairement définie, et un document officiel est créé pour préciser ce périmètre.

4.4 Système de management de la sécurité de l'information :

FinSecure s'engage à :

- **Établir un SMSI** → Définition des politiques de sécurité et mise en place d'un responsable de la sécurité (RSSI).
- **Mettre en œuvre le SMSI** → Basé sur une étude des risques : Déploiement d'un pare-feu, protection des bases de données, plan de gestion des incidents.....
- **Maintenir et améliorer** → Réalisation d'audits de sécurité réguliers, mise à jour continue des processus,...

Résultat : L'entreprise suit un processus d'amélioration continue pour garantir la sécurité de l'information.

19/02/2026

Dr Maha Charfeddine

69

Leadership

ISO/IEC 27001, article 5



5.1 Leadership et engagement

La direction doit s'assurer que le SMSI est compatible avec l'orientation stratégique de l'organisme.

La direction doit intégrer les exigences du SMSI dans les processus opérationnels de l'organisation, déterminer les ressources nécessaires au SMSI et communiquer l'importance d'un management efficace de la sécurité de l'information.



5.2 Politique

La direction doit élaborer une politique de sécurité de l'information qui doit être disponible et communiquée de manière appropriée à toutes les parties intéressées.

La politique doit être alignée sur la finalité de l'organisation et doit comprendre les objectifs de sécurité de l'information, un engagement à satisfaire aux exigences de sécurité de l'information et un engagement d'amélioration continue.



5.3 Rôles, responsabilités et autorités au sein de l'organisation

La direction doit attribuer les rôles et responsabilités appropriés en matière de sécurité de l'information afin de garantir que le système de management de la sécurité de l'information est conforme aux exigences d'ISO/IEC 27001.

19/02/2026

Dr Maha Charfeddine

70

ISO/IEC 27001, article 5.1 Leadership et engagement

La direction doit faire preuve de leadership et affirmer son engagement en faveur du système de management de la sécurité de l'information en :

- s'assurant qu'une politique et des objectifs sont établis en matière de sécurité de l'information et qu'ils sont compatibles avec l'orientation stratégique de l'organisation;
- s'assurant que les exigences liées au système de management de la sécurité de l'information sont intégrées aux processus métiers de l'organisation;
- s'assurant que les ressources nécessaires pour le système de management de la sécurité de l'information sont disponibles;
- communiquant sur l'importance de disposer d'un management de la sécurité de l'information efficace et de se conformer aux exigences du système de management de la sécurité de l'information;
- s'assurant que le système de management de la sécurité de l'information produit le ou les résultats escomptés;
- orientant et soutenant les personnes pour qu'elles contribuent à l'efficacité du système de management de la sécurité de l'information;
- promouvant l'amélioration continue; et
- aidant les autres managers concernés à faire également preuve de leadership dès lors que cela s'applique à leurs domaines de responsabilités.

19/02/2026

Dr Maha Charfeddine

71

ISO/IEC 27001, article 5.1 Leadership et engagement

L'entreprise FinSecure doit impliquer sa direction pour assurer un SMSI efficace et conforme.

5.1 Leadership et engagement

La direction de FinSecure doit :

- **Aligner le SMSI avec la stratégie de l'entreprise**
→ Ex. : FinSecure s'assure que la protection des données clients et la conformité réglementaire (RGPD, Loi 2004, PCI-DSS) sont
- **Intégrer la sécurité dans les processus métiers**
→ Ex. : Les contrôles de sécurité sont intégrés dans leset les échanges de données avec les partenaires.
- **Allouer les ressources nécessaires**
→ Ex. : Budget dédié à la cybersécurité, embauche d'unet formation du personnel.
- **Communiquer l'importance du SMSI**
→ Ex. : La direction organise des réunions pour sensibiliserà la protection des données.
- **S'assurer que les objectifs de sécurité sont atteints**
→ Ex. : Suivi des(ex. : taux d'incidents de cybersécurité, audits internes réussis).
- **Promouvoir l'amélioration continue**
→ Ex. : FinSecure réalise une revue du SMSI et met en place des plans d'action en fonction des risques émergents.

19/02/2026

Dr Maha Charfeddine

72

ISO/IEC 27001, article 5.1 Leadership et engagement

L'entreprise FinSecure doit impliquer sa direction pour assurer un SMSI efficace et conforme.

5.1 Leadership et engagement

La direction de FinSecure doit :

- **Aligner le SMSI avec la stratégie de l'entreprise**
→ Ex. : FinSecure s'assure que la protection des données clients et la conformité réglementaire (RGPD, Loi 2004, PCI-DSS) sont **des priorités stratégiques**.
- **Intégrer la sécurité dans les processus métiers**
→ Ex. : Les contrôles de sécurité sont **intégrés dans les transactions bancaires** et les échanges de données avec les partenaires.
- **Allouer les ressources nécessaires**
→ Ex. : Budget dédié à la cybersécurité, embauche d'un **Responsable de la Sécurité des Systèmes d'Information (RSSI)** et formation du personnel.
- **Communiquer l'importance du SMSI**
→ Ex. : La direction organise des réunions pour sensibiliser **tous les employés** à la protection des données.
- **S'assurer que les objectifs de sécurité sont atteints**
→ Ex. : Suivi des **indicateurs de performance** (ex. : taux d'incidents de cybersécurité, audits internes réussis).
- **Promouvoir l'amélioration continue**
→ Ex. : FinSecure réalise une **revue** du SMSI et met en place des plans d'action en fonction des risques émergents.

19/02/2026

Dr Maha Charfeddine

73

Politique de sécurité de l'information

ISO/IEC 27001, article 5.2

La direction doit établir une politique de sécurité de l'information qui :

- a) est adaptée à la mission de l'organisation;
- b) inclut des objectifs de sécurité de l'information ou fournit un cadre pour l'établissement de ces objectifs;
- c) inclut l'engagement de satisfaire aux exigences applicables en matière de sécurité de l'information;
- d) inclut l'engagement d'œuvrer pour l'amélioration continue du système de management de la sécurité de l'information.

La politique de sécurité de l'information doit :

- e) être disponible sous forme d'information documentée;
- f) être communiquée au sein de l'organisation;
- g) être mise à la disposition des parties intéressées, le cas échéant.

19/02/2026

Dr Maha Charfeddine

74

Politique de sécurité de l'information

ISO/IEC 27001, article 5.2

5.2 Politique de sécurité

La direction de FinSecure doit :

- **Définir une politique de sécurité claire**
→ Ex. : FinSecure s'engage à assurer des données financières de ses clients....
- **Communiquer cette politique**
→ Ex. : La politique est disponible sur de l'entreprise et est présentée aux nouveaux employés lors de leur intégration.
- **Fixer des objectifs mesurables**
→ Ex. : Diminuer de grâce à une formation pour les employés....
- **S'engager à l'amélioration continue**
→ Ex. : La direction **analyse régulièrement les incidents** et met en place des **actions**

19/02/2026

Dr Maha Charfeddine

75

Politique de sécurité de l'information

ISO/IEC 27001, article 5.2

5.2 Politique de sécurité

La direction de FinSecure doit :

- **Définir une politique de sécurité claire**
→ Ex. : FinSecure s'engage à assurer **la confidentialité, l'intégrité et la disponibilité** des données financières de ses clients....
- **Communiquer cette politique**
→ Ex. : La politique est disponible sur **l'intranet** de l'entreprise et est présentée aux nouveaux employés lors de leur intégration.
- **Fixer des objectifs mesurables**
→ Ex. : Diminuer de **30% les incidents liés au phishing** grâce à une formation obligatoire pour les employés....
- **S'engager à l'amélioration continue**
→ Ex. : La direction **analyse régulièrement les incidents** et met en place des **actions correctives**.

19/02/2026

Dr Maha Charfeddine

76

ISO/IEC 27001, article 5.3 Rôles, responsabilités et autorités au sein de l'organisme

La direction doit s'assurer que les responsabilités et autorités des rôles concernés par la sécurité de l'information sont attribuées et communiquées au sein de l'organisation.

La direction doit désigner qui a la responsabilité et l'autorité de:

- s'assurer que le système de management de la sécurité de l'information est conforme aux exigences du présent document;
- rendre compte à la direction des performances du système de management de la sécurité de l'information.

NOTE La direction peut également attribuer des responsabilités et autorités pour rendre compte des performances du système de management de la sécurité de l'information au sein de l'organisation.

19/02/2026

Dr Maha Charfeddine

77

ISO/IEC 27001, article 5.3 Rôles, responsabilités et autorités au sein de l'organisme

5.3 Rôles, responsabilités et autorités

La direction de FinSecure doit :

• Attribuer des responsabilités précises

→ Ex. :

- RSSI :
- DPO (Délégué à la protection des données) : Garant de la conformité RGPD, loi 2004.
- Équipe IT :

• S'assurer que chaque acteur connaît son rôle

→ Ex. : Le RSSI pilote, consolide et présente les KPI du SMSI à la direction, tandis que les responsables métiers doivent appliquer les contrôles de sécurité dans leur domaine.

• Garantir la conformité avec ISO 27001

→ Ex. : Des sont réalisés pour s'assurer que chacun respecte les procédures.

19/02/2026

Dr Maha Charfeddine

78

ISO/IEC 27001, article 5.3 Rôles, responsabilités et autorités au sein de l'organisme

5.3 Rôles, responsabilités et autorités

La direction de FinSecure doit :

• Attribuer des responsabilités précises

→ Ex. :

- RSSI : **Responsable de la sécurité des systèmes d'information.**
- DPO (Délégué à la protection des données) : Garant de la conformité RGPD, loi 2004.
- Équipe IT : **Gestion de l'infrastructure et des accès.**

• S'assurer que chaque acteur connaît son rôle

→ Ex. : Le RSSI pilote, consolide et présente les KPI du SMSI à la direction, tandis que les responsables métiers doivent appliquer les contrôles de sécurité dans leur domaine.

• Garantir la conformité avec ISO 27001

→ Ex. : Des **audits internes** sont réalisés pour s'assurer que chacun respecte les procédures.

19/02/2026

Dr Maha Charfeddine

79

Planification

ISO/IEC 27001, article 6



L'organisme doit établir les risques et les opportunités d'atteindre les résultats escomptés, de prévenir ou de réduire les effets indésirables et de parvenir à une amélioration continue. L'organisme doit également planifier des actions pour faire face aux risques et aux opportunités, mettre en œuvre ces actions et évaluer leur efficacité.

Les objectifs de l'organisme doivent être mesurables et cohérents avec la politique de sécurité de l'information. Ils doivent également être alignés sur les exigences et les résultats de l'appréciation des risques et du traitement. Les objectifs doivent être surveillés, communiqués de manière appropriée, mis à jour et disponibles sous forme d'informations documentées.

L'organisation doit déterminer s'il est nécessaire de modifier le SMSI, puis mettre en œuvre ces modifications de manière planifiée.

19/02/2026

Dr Maha Charfeddine

80

Planification

ISO/IEC 27001, article 6

6.1 Actions liées aux risques et opportunités

- **Identification des risques et opportunités**
→ Ex. : FinSecure réalise une analyse de et les **opportunités** (nouveaux outils de cybersécurité).
- **Mise en place d'actions préventives**
→ Ex. : Pour réduire les risques de **phishing**, l'entreprise implémente une authentification multi-facteurs (MFA) pour les employés.
- **Suivi de l'efficacité des actions**
→ Ex. : Après la mise en place du MFA, FinSecure organise des pour évaluer le comportement des employés et l'efficacité des mesures de sensibilisation.
- **Bénéfice : Cette approche permet d'anticiper les menaces et d'adapter en permanence les mesures de protection.**

24/02/2026

Dr Maha Charfeddine

81

Planification

ISO/IEC 27001, article 6

6.1 Actions liées aux risques et opportunités

- **Identification des risques et opportunités**
→ Ex. : FinSecure réalise une **analyse des risques** et les **opportunités** (nouveaux outils de cybersécurité).
- **Mise en place d'actions préventives**
→ Ex. : Pour réduire les risques de **phishing**, l'entreprise implémente une **authentification multi-facteurs (MFA)** pour les employés.
- **Suivi de l'efficacité des actions**
→ Ex. : Après la mise en place du MFA, FinSecure organise des **campagnes de simulation de phishing** pour évaluer le comportement des employés et l'efficacité des mesures de sensibilisation.
- **Bénéfice : Cette approche permet d'anticiper les menaces et d'adapter en permanence les mesures de protection.**

19/02/2026

Dr Maha Charfeddine

82

Planification

ISO/IEC 27001, article 6

6.2 Objectifs de sécurité de l'information et plans pour les atteindre

- **Définition d'objectifs mesurables et alignés avec la politique de sécurité**
→ Ex. :
Réduire de **50% les tentatives d'accès non autorisé** d'ici un an.
Effectuer **deux audits internes de sécurité** par an.
Former **100% des employés** à la cybersécurité d'ici la fin de l'année.
- **Surveillance et mise à jour des objectifs**
→ Ex. : L'entreprise utilise un pour suivre l'évolution des indicateurs.
- **Bénéfice : Cette démarche assure une et une conformité aux réglementations (RGPD, loi 2004, PCI-DSS, ...).**

19/02/2026

Dr Maha Charfeddine

83

Planification

ISO/IEC 27001, article 6

6.2 Objectifs de sécurité de l'information et plans pour les atteindre

- **Définition d'objectifs mesurables et alignés avec la politique de sécurité**
→ Ex. :
Réduire de **50% les tentatives d'accès non autorisé** d'ici un an.
Effectuer **deux audits internes de sécurité** par an.
Former **100% des employés** à la cybersécurité d'ici la fin de l'année.
- **Surveillance et mise à jour des objectifs**
→ Ex. : L'entreprise utilise un **tableau de bord de sécurité** pour suivre l'évolution des indicateurs.
- **Bénéfice : Cette démarche assure une **amélioration continue** et une **conformité aux réglementations** (RGPD, loi 2004, PCI-DSS, ...).**

19/02/2026

Dr Maha Charfeddine

84

Planification

ISO/IEC 27001, article 6

6.3 Planification des changements

- Déterminer si des changements sont nécessaires

→ Ex. : Suite à une **nouvelle réglementation bancaire**, FinSecure doit modifier sa politique de gestion des accès.

- **Renforçant l'authentification** (ex. : passage à l'authentification multi-facteurs pour tous les employés).
- **Réduisant les accès non nécessaires** selon le principe du (un employé ne peut accéder qu'aux données essentielles à son travail).
- **Mettant en place un suivi et une stricte** (journalisation des connexions et alertes en cas d'accès suspect).
- **Formant les employés** aux nouvelles règles de sécurité d'accès.

- Mise en œuvre des modifications de manière contrôlée

→ Ex. : Avant d'installer une nouvelle solution de chiffrement, l'entreprise effectue des et prévoit une formation du personnel.

Bénéfice : Les changements sont, **planifiés et maîtrisés**, garantissant une **sécurité sans perturbation des opérations**.

19/02/2026

Dr Maha Charfeddine

85

Planification

ISO/IEC 27001, article 6

6.3 Planification des changements

- Déterminer si des changements sont nécessaires

→ Ex. : Suite à une **nouvelle réglementation bancaire**, FinSecure doit modifier sa politique de gestion des accès.

- **Renforçant l'authentification** (ex. : passage à l'authentification multi-facteurs pour tous les employés).
- **Réduisant les accès non nécessaires** selon le principe du **moindre privilège** (un employé ne peut accéder qu'aux données essentielles à son travail).
- **Mettant en place un suivi et une traçabilité stricte** (journalisation des connexions et alertes en cas d'accès suspect).
- **Formant les employés** aux nouvelles règles de sécurité d'accès.

- Mise en œuvre des modifications de manière contrôlée

→ Ex. : Avant d'installer une nouvelle solution de chiffrement, l'entreprise effectue des **tests** et prévoit une formation du personnel.

Bénéfice : Les changements sont **anticipés**, **planifiés et maîtrisés**, garantissant une **sécurité sans perturbation des opérations**.

19/02/2026

Dr Maha Charfeddine

86

ISO/IEC 27001, article 6.1 Actions liées aux risques et opportunités

6.1.1 Généralités

Lorsqu'elle conçoit son système de management de la sécurité de l'information, l'organisation doit tenir compte des enjeux de 4.1 et des exigences de 4.2, et déterminer les risques et opportunités qui nécessitent d'être abordés pour:

- a. s'assurer que le système de management de la sécurité de l'information peut atteindre le ou les résultats escomptés;
- b. empêcher ou limiter les effets indésirables;
- c. appliquer une démarche d'amélioration continue.

L'organisation doit planifier:

d. les actions menées pour traiter ces risques et opportunités; et

e. la manière:

1. d'intégrer et de mettre en œuvre les actions au sein des processus du système de management de la sécurité de l'information; et
2. d'évaluer l'efficacité de ces actions.

19/02/2026

Dr Maha Charfeddine

87

ISO/IEC 27001, article 6.1 Actions liées aux risques et opportunités

6.1.1 Généralités

FinSecure doit :

1. S'assurer que son SMSI atteint les résultats attendus

→ Ex. : FinSecure vise une **réduction des de cybersécurité** grâce à une meilleure gestion des accès aux données.

2. Limiter les effets indésirables

→ Ex. : Pour éviter les **fuites de clients**, l'entreprise applique le **chiffrement des données** et renforce l'authentification des utilisateurs.

3. Appliquer une amélioration continue

→ Ex. : FinSecure effectue des **réguliers** pour identifier et corriger les failles de sécurité.

19/02/2026

Dr Maha Charfeddine

88

ISO/IEC 27001, article 6.1 Actions liées aux risques et opportunités

6.1.1 Généralités

FinSecure doit :

1. S'assurer que son SMSI atteint les résultats attendus

→ Ex. : FinSecure vise une **réduction des incidents** de cybersécurité grâce à une meilleure gestion des accès aux données.

2. Limiter les effets indésirables

→ Ex. : Pour éviter les **fuites de données** clients, l'entreprise applique le **chiffrement des données** et renforce l'authentification des utilisateurs.

3. Appliquer une amélioration continue

→ Ex. : FinSecure effectue des **tests d'intrusion** réguliers pour identifier et corriger les failles de sécurité.

19/02/2026

Dr Maha Charfeddine

89

ISO/IEC 27001, article 6.1 Actions liées aux risques et opportunités

6.1.1 Généralités

Planification des actions

FinSecure doit planifier :

1. Des actions pour traiter les risques et opportunités

1. Ex. **Risque** : Attaque par rançongiciel

Mise en place deet test de restauration régulière.

2. Ex. **Opportunité** : Adoption du **Zero Trust**

Implémentation d'un contrôle strict des accès basé sur l'identité et le comportement des utilisateurs (**Fréquence et horaires de connexion, Localisation, Type d'appareil utilisé, Actions inhabituelles**)

2. L'intégration des actions dans le SMSI

Ex. : Les **protocoles de gestion des accès** sont intégrés dans tous les processus métiers (ex. : banques, paiements en ligne).

3. L'évaluation de l'efficacité des actions

Ex. : FinSecure analyse les **tentatives d'attaques bloquées** pour ajuster ses défenses.

19/02/2026

Dr Maha Charfeddine

90

ISO/IEC 27001, article 6.1 Actions liées aux risques et opportunités

6.1.1 Généralités

Planification des actions

FinSecure doit planifier :

1. Des actions pour traiter les risques et opportunités

1. Ex. **Risque** : Attaque par rançongiciel

Mise en place de **sauvegardes** chiffrées et test de restauration régulière.

2. Ex. **Opportunité** : Adoption du **Zero Trust**

Implémentation d'un contrôle strict des accès basé sur l'identité et le comportement des utilisateurs (**Fréquence et horaires de connexion, Localisation, Type d'appareil utilisé, Actions inhabituelles**)

2. L'intégration des actions dans le SMSI

Ex. : Les **protocoles de gestion des accès** sont intégrés dans tous les processus métiers (ex. : banques, paiements en ligne).

3. L'évaluation de l'efficacité des actions

Ex. : FinSecure analyse les **tentatives d'attaques bloquées** pour ajuster ses défenses.

19/02/2026

Dr Maha Charfeddine

91

Approche de l'appréciation des risques de sécurité de l'information

ISO/IEC 27005, article 7.1

- Il convient que l'organisme utilise le processus d'appréciation du risque organisationnel (s'il est établi) pour apprécier les risques pour l'information ou pour définir un processus d'appréciation du risque lié à la sécurité de l'information.
- L'appréciation du risque permet aux propriétaires du risque de classer les risques par ordre de priorité en fonction de la perspective de traitement, en se basant principalement sur leurs conséquences et leur vraisemblance ou sur d'autres critères établis.



19/02/2026

Dr Maha Charfeddine

92

ISO/IEC 27001, article 6.1.2 Appréciation des risques de sécurité de l'information

L'organisme doit définir et appliquer un processus d'appréciation des risques de sécurité de l'information qui:

- a. établit et tient à jour les critères de risque de sécurité de l'information incluant:
 1. les critères d'acceptation des risques;
 2. les critères de réalisation des appréciations des risques de sécurité de l'information;
- b. s'assure que la répétition de ces appréciations des risques produit des résultats cohérents, valides et comparables;
- c. identifie les risques de sécurité de l'information:
 1. applique le processus d'appréciation des risques de sécurité de l'information pour identifier les risques liés à la perte de confidentialité, d'intégrité et de disponibilité des informations entrant dans le domaine d'application du système de management de la sécurité de l'information; et
 2. identifie les propriétaires des risques;
- d. analyse les risques de sécurité de l'information:
 1. apprécie les conséquences potentielles dans le cas où les risques identifiés en 6.1.2 c) 1) se concrétisaient;
 2. procède à une évaluation réaliste de la vraisemblance d'apparition des risques identifiés en 6.1.2 c) 1); et
 3. détermine les niveaux des risques;
- e. évalue les risques de sécurité de l'information:
 1. compare les résultats d'analyse des risques avec les critères de risque déterminés en 6.1.2 a); et
 2. priorise les risques analysés pour le traitement des risques.

L'organisation doit conserver des informations documentées sur le processus d'appréciation des risques de sécurité de l'information.

19/02/2026

Dr Maha Charfeddine

94

ISO/IEC 27001, article 6.1.2 Appréciation des risques de sécurité de l'information

Exemple 1 : FinSecure, est confrontée à une menace croissante liée aux attaques de phishing.

Critères de réalisation des appréciations des risques

Objectif : Déterminer comment évaluer le risque de phishing (probabilité, impact, criticité du risque).

Exemple de Scénario d'attaque de phishing évalué par FinSecure :

- Un client reçoit un email se faisant passer pour FinSecure, lui demandant de se connecter via un faux site.
- Il saisit ses identifiants, qui sont **capturés par l'attaquant**.
- Une **transaction frauduleuse** est réalisée sur son compte.

Impacts : Vol de fonds, plainte du client, atteinte à la réputation de FinSecure

19/02/2026

Dr Maha Charfeddine

94

ISO/IEC 27001, article 6.1.2 Appréciation des risques de sécurité de l'information

Critères de réalisation des appréciations des risques

Méthodologie choisie : Approche utilisant une matrice de risque combinant probabilité et impact.

Facteur	Critère retenu	Évaluation spécifique au phishing
Probabilité (P)	Fréquence d'apparition de l'attaque	Score : 4/5 (attaques fréquentes dans le secteur financier).
Impact (I)	Conséquences financières, réputationnelles, réglementaires	Score : 5/5 (perte d'argent des clients, amendes réglementaires, perte de confiance).
Actifs concernés	Données clients, accès aux comptes, infrastructures IT.	
Menaces identifiées	Emails frauduleux, faux sites bancaires	
Vulnérabilités associées	Manque de sensibilisation des employés et clients, absence de MFA	
Seuil de criticité	Niveau de risque ($R = P \times I$)	Score : 20/25 (risque critique).

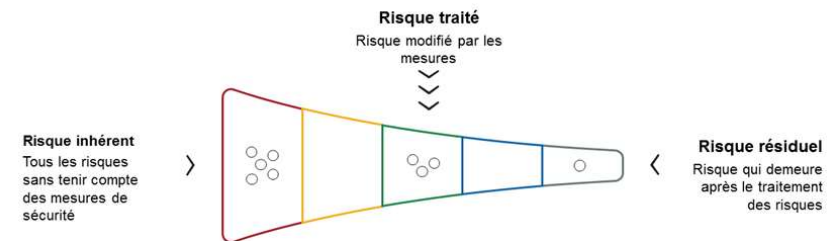
Conclusion : Ce risque est élevé et nécessite des mesures de mitigation prioritaires.

19/02/2026

Dr Maha Charfeddine

95

Risque résiduel



Les propriétaires de risque doivent être informés des risques résiduels et en accepter la responsabilité.

19/02/2026

Dr Maha Charfeddine

96

ISO/IEC 27001, article 6.1.2 Appréciation des risques de sécurité de l'information

Critères d'acceptation des risques

Objectif : Déterminer si le risque **résiduel** après mise en œuvre des mesures est acceptable.

Évaluation après mise en place de mesures de sécurité :

Mesures de sécurité appliquées	Effet sur le risque résiduel	Résultat
Mise en place de l'authentification multi-facteurs (MFA)	Réduit les risques de compromission même si l'identifiant est volé.	Réduction du risque.
Formation et sensibilisation des employés et clients	Diminue la probabilité qu'un utilisateur tombe dans le piège.	Réduction de la probabilité.
Blocage automatique des liens malveillants dans les emails (filtrage anti-phishing avancé)	Diminue les chances que le client clique sur un lien malveillant.	Réduction de la menace.
Surveillance des connexions suspectes (SIEM, détection d'anomalies)	Permet de détecter et bloquer une connexion frauduleuse en temps réel.	Détection proactive.

Seuil d'acceptation du risque par FinSecure :

- FinSecure accepte **seulement les risques résiduels faibles à modérés.**
- Après application des mesures correctives, le **risque résiduel tombe à 6/25 (modéré).**
- **Ce risque est acceptable**, car les mesures mises en place garantissent **une protection suffisante.**

19/02/2026

Dr Maha Charfeddine

97

ISO/IEC 27001, article 6.1.2 Appréciation des risques de sécurité de l'information

Résumé des différences dans le cas du Phishing

Type de critère	Application chez FinSecure (phishing)
Critères de Réalisation des Appréciations des Risques	Définition de comment évaluer le phishing (probabilité, impact, criticité du risque).
Critères d'Acceptation des Risques	Définition de quand FinSecure considère le phishing comme un risque acceptable après mitigation .

Avant traitement, le phishing était un risque critique (20/25).

Après traitement, il devient un risque modéré (6/25) et acceptable selon les critères de FinSecure.

Conclusion : En suivant cette approche, FinSecure garantit **une évaluation rigoureuse du risque de phishing et une prise de décision éclairée** pour gérer le risque résiduel.

19/02/2026

Dr Maha Charfeddine

98

ISO/IEC 27001, article 6.1.2 Appréciation des risques de sécurité de l'information

L'organisme doit définir et appliquer un processus d'appréciation des risques de sécurité de l'information qui:

- établit et tient à jour les critères de risque de sécurité de l'information incluant:
 - les critères d'acceptation des risques;
 - les critères de réalisation des appréciations des risques de sécurité de l'information;
- s'assure que la répétition de ces appréciations des risques produit des résultats cohérents, valides et comparables;
- identifie les risques de sécurité de l'information:
 - applique le processus d'appréciation des risques de sécurité de l'information pour identifier les risques liés à la perte de confidentialité, d'intégrité et de disponibilité des informations entrant dans le domaine d'application du système de management de la sécurité de l'information; et
 - identifie les propriétaires des risques;
- analyse les risques de sécurité de l'information:
 - apprécie les conséquences potentielles dans le cas où les risques identifiés en 6.1.2 c) 1) se concrétisaient;
 - procède à une évaluation réaliste de la vraisemblance d'apparition des risques identifiés en 6.1.2 c) 1); et
 - détermine les niveaux des risques;
- évalue les risques de sécurité de l'information:
 - compare les résultats d'analyse des risques avec les critères de risque déterminés en 6.1.2 a); et
 - priorise les risques analysés pour le traitement des risques.

L'organisation doit conserver des informations documentées sur le processus d'appréciation des risques de sécurité de l'information.

Points b, c, d et e de la clause 6.1.2

b) Assurer la cohérence des appréciations des risques

Exigence ISO 27001 : L'organisation doit garantir que **chaque analyse des risques est reproductible et cohérente.**

Les résultats doivent être **comparables et valides**, permettant une prise de décision basée sur des données fiables.

Application chez FinSecure :

- **Méthodologie normalisée :** FinSecure utilise toujours **la même grille d'évaluation** pour analyser les cyberattaques (probabilité/impact).
- **Utilisation d'outils SIEM** (Security Information and Event Management) pour **centraliser et analyser** les données des menaces de phishing détectées.
- **Rapports réguliers :** Tous les mois, un rapport de sécurité est généré pour comparer **l'évolution du phishing** et l'efficacité des mesures mises en place.

Comparabilité des évaluations : **Une attaque de phishing est toujours évaluée de la même manière pour éviter les biais dans la prise de décision.**

Exemple :

- En janvier 2024, FinSecure a détecté 100 tentatives de phishing avec **un taux de réussite de 5%.**
- Après mise en place de formations et filtres email avancés, en mars 2024, seulement 30 tentatives sont détectées avec **1% de succès.**

La méthodologie reste identique, garantissant des résultats cohérents pour adapter la stratégie de défense.

19/02/2026

Dr Maha Charfeddine

100

Points b, c, d et e de la clause 6.1.2

c) Identification des risques de sécurité de l'information

1. Appliquer le processus d'appréciation des risques pour le phishing

Exigence ISO 27001 :

L'entreprise doit identifier les menaces qui compromettent **la confidentialité, l'intégrité et la disponibilité** des informations.

Application chez FinSecure /phishing:

Confidentialité :

Intégrité :

Disponibilité :

Exemple :

- Un employé clique sur un email de phishing et **fournit ses identifiants**.
- L'attaquant utilise son accès pour **modifier des configurations** dans le système bancaire.
- FinSecure **bloque temporairement certains accès**, impactant la disponibilité des services.

19/02/2026

Dr Maha Charfeddine

101

Points b, c, d et e de la clause 6.1.2

c) Identification des risques de sécurité de l'information

1. Appliquer le processus d'appréciation des risques pour le phishing

Exigence ISO 27001 :

L'entreprise doit identifier les menaces qui compromettent la confidentialité, l'intégrité et la disponibilité des informations.

Application chez FinSecure/phishing :

Confidentialité : Un phishing réussi peut voler les identifiants bancaires des clients.

Intégrité : Un attaquant peut modifier des transactions financières en exploitant des comptes compromis.

Disponibilité : Un phishing ciblé peut déstabiliser le support client avec une vague massive de fraudes à gérer.

Exemple :

- Un employé clique sur un email de phishing et **fournit ses identifiants**.
- L'attaquant utilise son accès pour **modifier des configurations** dans le système bancaire.
- FinSecure **bloque temporairement certains accès**, impactant la disponibilité des services.

19/02/2026

Dr Maha Charfeddine

102

Points b, c, d et e de la clause 6.1.2

2. Identifier les propriétaires des risques

Exigence ISO 27001 :

Chaque risque doit être attribué à un **responsable** qui en assurera la surveillance et la réduction.

Application chez FinSecure :

RSSI (Responsable de la Sécurité des Systèmes d'Information) : Responsable de

Responsable IT Sécurité : Assureet filtres anti-phishing.

Équipe de formation interne :

Service support client : Traite les plaintes en cas d'attaque réussie et guide les clients sur les actions à suivre.

.....

Exemple :

Lorsqu'une attaque de phishing est détectée, le **RSSI** active un **plan de réponse**, tandis que le **support client** alerte les utilisateurs potentiellement victimes.

19/02/2026

Dr Maha Charfeddine

103

Points b, c, d et e de la clause 6.1.2

2. Identifier les propriétaires des risques

Exigence ISO 27001 :

Chaque risque doit être attribué à un **responsable** qui en assurera la surveillance et la réduction.

Application chez FinSecure :

RSSI (Responsable de la Sécurité des Systèmes d'Information) : Responsable de la gestion globale des cybermenaces.

Responsable IT Sécurité : Assure la mise en place des pare-feux et filtres anti-phishing.

Équipe de formation interne : Sensibilise les employés et les clients aux risques du phishing.

Service support client : Traite les plaintes en cas d'attaque réussie et guide les clients sur les actions à suivre.

.....

Exemple :

Lorsqu'une attaque de phishing est détectée, le **RSSI** active un **plan de réponse**, tandis que le **support client** alerte les utilisateurs potentiellement victimes.

19/02/2026

Dr Maha Charfeddine

104

Points b, c, d et e de la clause 6.1.2

d) Analyse des risques de sécurité de l'information

1. Apprécier les conséquences potentielles si le phishing réussit

Exigence ISO 27001 :

L'entreprise doit évaluer l'impact potentiel en cas d'attaque réussie.

Application chez FinSecure :

.....si un attaquant réalise des transactions frauduleuses.
 si plusieurs clients sont victimes et médiatisent leur expérience.
 si FinSecure ne protège pas correctement les données des clients.

Exemple :

Un hacker usurpe l'identité de FinSecure et envoie 10 000 emails frauduleux à des clients.

- 10% d'entre eux tombent dans le piège et fournissent leurs identifiants.
- 2 millions d'euros sont détournés avant détection.
- La banque doit rembourser les victimes et renforcer ses mesures.

19/02/2026

Dr Maha Charfeddine

105

Points b, c, d et e de la clause 6.1.2

d) Analyse des risques de sécurité de l'information

1. Apprécier les conséquences potentielles si le phishing réussit

Exigence ISO 27001 :

L'entreprise doit évaluer l'impact potentiel en cas d'attaque réussie.

Application chez FinSecure :

Perte de fonds clients si un attaquant réalise des transactions frauduleuses.
 Réputation endommagée si plusieurs clients sont victimes et médiatisent leur expérience.
 Sanctions réglementaires si FinSecure ne protège pas correctement les données des clients.

Exemple :

Un hacker usurpe l'identité de FinSecure et envoie 10 000 emails frauduleux à des clients.

- 10% d'entre eux tombent dans le piège et fournissent leurs identifiants.
- 2 millions d'euros sont détournés avant détection.
- La banque doit rembourser les victimes et renforcer ses mesures.

19/02/2026

Dr Maha Charfeddine

106

Points b, c, d et e de la clause 6.1.2

2. Évaluer la vraisemblance d'une attaque de phishing réussie

Exigence ISO 27001 :

L'entreprise doit évaluer la probabilité qu'une attaque aboutisse.

Application chez FinSecure :

Avant filtrage avancé : 80% des attaques de phishing parviennent dans les boîtes email.

Après filtrage avancé : Seulement 5% des attaques atteignent les destinataires.

Après formation : Le taux de clics sur des emails malveillants passe de 30% à 5%.

Exemple :

- Probabilité initiale d'une attaque réussie : Élevée (4/5).
- Probabilité après mesures : Faible (2/5).

19/02/2026

Dr Maha Charfeddine

107

Points b, c, d et e de la clause 6.1.2

3. Déterminer les niveaux de risque

Exigence ISO 27001 :

L'entreprise doit affecter un score global au risque en combinant probabilité et impact.

Critère	Avant mesures	Après mesures
Probabilité (P)	4/5 (attaque fréquente)	2/5 (beaucoup plus filtrée)
Impact (I)	5/5 (pertes financières lourdes)	2/5 (quelques cas isolés)
Niveau de risque (R = P x I)	20/25 (Critique)	4/25 (Faible -> Acceptable)

Le risque de phishing est passé de "Critique" à "Acceptable" après traitement.

19/02/2026

Dr Maha Charfeddine

108

Points b, c, d et e de la clause 6.1.2

e) Évaluation des risques et priorisation

1. Comparer les résultats avec les critères d'acceptation des risques

Exigence ISO 27001 :

L'entreprise doit voir si le **risque résiduel** est acceptable selon les seuils définis.

Application chez FinSecure :

Avant traitement : **Risque de 20/25 (inacceptable).**

Après traitement : **Risque de 4/25 (acceptable selon la politique de gestion des risques <=6/25).**

Décision : Le phishing n'est plus une menace critique, mais reste surveillé en continu.

19/02/2026

Dr Maha Charfeddine

109

Points b, c, d et e de la clause 6.1.2

2. Prioriser les risques analysés

Exigence ISO 27001 :

L'entreprise doit classer les risques les **plus urgents** pour allouer les ressources.

Application chez FinSecure :

Le phishing était une priorité n°1, mais après traitement, il est relégué en priorité n°3.

Les attaques DDoS restent une menace critique et passent en priorité n°1.

Décision : FinSecure réoriente une partie de son budget vers la protection contre DDoS et l'amélioration des pare-feu.

19/02/2026

Dr Maha Charfeddine

110

Traitement du risque

ISO/IEC 27001, article 6.1.3

L'organisation doit définir et appliquer un processus de traitement des risques de sécurité de l'information pour:

a) choisir les options de traitement des risques appropriées, en tenant compte des résultats de l'appréciation des risques;

b) déterminer toutes les mesures nécessaires à la mise en œuvre de(s) l'option(s) de traitement des risques de sécurité de l'information choisie(s);

NOTE 1 Les organisations peuvent concevoir ces mesures, le cas échéant, ou bien les identifier à partir de n'importe quelle source.

c) comparer les mesures déterminées ci-dessus en 6.1.3 b) avec celles de l'Annexe A et vérifier qu'aucune mesure nécessaire n'a été omise;

NOTE 2 L'Annexe A comporte une liste des mesures possibles de la sécurité de l'information. Les utilisateurs du présent document sont invités à se reporter à l'Annexe A pour s'assurer qu'aucune mesure de sécurité de l'information nécessaire n'a été négligée.

NOTE 3 Les mesures de sécurité de l'information énumérés dans l'Annexe A ne sont pas exhaustives et des mesures de sécurité de l'information additionnelles peuvent s'avérer nécessaires.

19/02/2026

Dr Maha Charfeddine

111

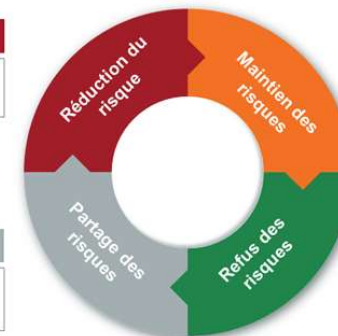
Évaluer les options de traitement des risques

Réduction du risque

Mesures de sécurité sélectionnées pour réduire les risques

Partage des risques

Décision de partager les risques avec les parties externes : assurance ou externalisation



Maintien des risques

Décision de la direction de prendre le risque

Refus des risques

Annulation ou modification d'une ou plusieurs activités liées aux risques

19/02/2026

Dr Maha Charfeddine

112

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

Traitement du risque chez FinSecure selon l'ISO 27001 - Clause 6.1.3

1. Choix des options de traitement des risques (6.1.3 a)

FinSecure doit décider **quelle option adopter pour chaque risque** identifié après l'analyse.

Risque	Option de traitement choisie	Explication
Phishing		Déploiement d'une authentification multi-facteurs (MFA) et d'un filtrage avancé des emails, ...
DDoS		Utilisation d'un fournisseur externe pour filtrer les attaques DDoS.
Fraude bancaire interne		FinSecure décide d'accepter un faible risque de fraude en interne, compensé par des audits réguliers.
Non-conformité RGPD		Suppression des données inutiles pour éviter d'avoir à les protéger.

19/02/2026

Dr Maha Charfeddine

113

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

Traitement du risque chez FinSecure selon l'ISO 27001 - Clause 6.1.3

1. Choix des options de traitement des risques (6.1.3 a)

FinSecure doit décider **quelle option adopter pour chaque risque** identifié après l'analyse.

Risque	Option de traitement choisie	Explication
Phishing	Réduction du risque	Déploiement d'une authentification multi-facteurs (MFA) et d'un filtrage avancé des emails, ...
DDoS	Partage du risque	Utilisation d'un fournisseur externe pour filtrer les attaques DDoS.
Fraude bancaire interne	Maintien du risque	FinSecure décide d'accepter un faible risque de fraude en interne, compensé par des audits réguliers.
Non-conformité RGPD	Refus du risque	Suppression des données inutiles pour éviter d'avoir à les protéger.

19/02/2026

Dr Maha Charfeddine

114

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

2. Détermination des mesures de sécurité nécessaires (6.1.3 b)

FinSecure doit **définir et appliquer** les mesures adéquates pour sécuriser son système d'information.

Actions mises en place pour le risque de Phishing :

.....

19/02/2026

Dr Maha Charfeddine

115

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

2. Détermination des mesures de sécurité nécessaires (6.1.3 b)

FinSecure doit **définir et appliquer** les mesures adéquates pour sécuriser son système d'information.

Actions mises en place pour le risque de Phishing :

- Mise en place de formations régulières pour les employés.
- Déploiement d'une authentification multi-facteurs (MFA)
- Filtrage avancé des emails
- Ajout d'un système SIEM pour surveiller les connexions suspectes

19/02/2026

Dr Maha Charfeddine

116

Sélectionner les mesures de sécurité

ISO/IEC 27005, article 8.3

Mesures de sécurité de l'information applicables

Revue et sélection

1. Les organismes sont libres de choisir ou d'identifier des mesures potentielles provenant de différentes normes ou sources (par exemple, la législation, les meilleures pratiques de l'industrie) qu'ils jugent appropriées et applicables.
2. Néanmoins, les organismes sont tenus d'examiner les 93 mesures de sécurité d'ISO/IEC 27001 au cas où ils auraient manqué ou négligé de les choisir. Toute mesure omise que les organismes jugent non applicable à leur contexte doit être justifiée et incluse dans la Déclaration d'applicabilité.
3. La plupart des organismes choisissent la majorité des mesures de sécurité de l'Annexe A d'ISO/IEC 27001 comme étant appropriées pour leur appréciation des risques.

19/02/2026

Dr Maha Charfeddine

117

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

3. Vérification des mesures de sécurité avec l'Annexe A (6.1.3 c)

L'ISO 27001 propose dans l'Annexe A, 93 mesures de sécurité recommandées. FinSecure doit vérifier que toutes les mesures nécessaires sont bien couvertes.

Application chez FinSecure :

- Comparaison des contrôles de sécurité existants avec l'Annexe A.
- Si une mesure est absente, évaluation du risque et justification de son exclusion.

19/02/2026

Dr Maha Charfeddine

118

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

- d) produire une déclaration d'applicabilité contenant:
- les mesures nécessaires (voir 6.1.3 b) et c));
 - la justification de leur insertion;
 - le fait que les mesures nécessaires soient mises en œuvre ou non; et
 - la justification de l'exclusion de toute mesure de l'Annexe A.
- e) élaborer un plan de traitement des risques de sécurité de l'information; et
- f) obtenir des propriétaires des risques l'approbation du plan de traitement des risques et l'acceptation des risques résiduels de sécurité de l'information.

L'organisation doit conserver des informations documentées sur le processus de traitement des risques de sécurité de l'information.

NOTE 4 L'appréciation des risques de sécurité de l'information et le processus de traitement figurant dans le présent document s'alignent sur les principes et les lignes directrices générales fournies dans l'ISO 31000.

19/02/2026

Dr Maha Charfeddine

119

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

4. Production d'une Déclaration d'Applicabilité (6.1.3 d)

FinSecure doit documenter les mesures de sécurité mises en place et celles qui sont exclues.

Exemple de justification liée à une mesure sélectionnée :

ISO/IEC 27001, Annexe A 5.29 Sécurité de l'information au cours de perturbation

L'organisation doit planifier la manière de maintenir la sécurité des informations à un niveau approprié en cas de perturbation.

Justification de la sélection : Car la non disponibilité de l'information en temps opportun lorsqu'une interruption ou une panne, affecte **négativement** les processus métier essentiels.

19/02/2026

Dr Maha Charfeddine

120

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

4. Production d'une Déclaration d'Applicabilité (6.1.3 d)

FinSecure doit documenter les mesures de sécurité mises en place et celles qui sont exclues.

Exemple de justification liée à une mesure exclue :

ISO/IEC 27001, Annexe A 6.7 Travail à distance

Des mesures de sécurité doivent être mises en œuvre lorsque le personnel travaille à distance afin de protéger les informations consultées, traitées ou stockées en dehors des locaux de l'organisation.

Justification de l'exclusion : Le travail à distance est interdit dans l'organisme/Notre organisme n'a aucune activité liée au travail à distance

19/02/2026

Dr Maha Charfeddine

121

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

4. Production d'une Déclaration d'Applicabilité (6.1.3 d)

FinSecure doit documenter les mesures de sécurité mises en place et celles qui sont exclues.

Exemple de déclaration d'applicabilité :

Mesure	Applicable	Description	Justification	Documentation	Responsable
A.5.1 Politiques de sécurité de l'information	Oui	La politique de sécurité est revue chaque année lors de la revue de direction et une résolution formelle la reconduit pour une année supplémentaire. En cas de changements majeurs, une révision peut avoir lieu en cours d'année à la demande du RSSI	Assurer que la politique de sécurité est maintenue à jour et qu'elle demeure alignée sur les objectifs de l'organisme	1. Procédure-revue-direction-312PR 2. Politique-sécurité-3213PO, article 6.2 3. Procédures de revue de direction 2018	Responsable de la sécurité de l'information
A.6.7 Travail à distance	Non	-----	Notre organisme n'a aucune activité liée au travail à distance	Aucun document	Responsable des TI

19/02/2026

Dr Maha Charfeddine

122

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

5.Élaboration d'un plan de traitement des risques (6.1.3 e)

- Une fois que les décisions relatives aux options de traitement des risques ont été prises, les activités visant à mettre en œuvre ces décisions doivent être planifiées.
- Les activités devraient être classées en fonction de leur priorité. Les ressources nécessaires doivent être allouées au plan de traitement.

Exemple simplifié de plan de traitement des risques chez FinSecure pour le phishing :

Action	Responsable	Délai
Déploiement du SIEM	RSSI	3 mois
Formation des employés	DRH + RSSI	6 mois
Blocage des liens malveillants	IT Sécurité	2 mois

19/02/2026

Dr Maha Charfeddine

123

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

6.Validation et approbation des risques résiduels (6.1.3 f)

FinSecure doit documenter et valider le niveau de risque résiduel acceptable après traitement.

Exemple :

Si un risque résiduel dépasse le seuil acceptable, de nouvelles actions doivent être mises en place

Risque	Risque Inhérent	Traitement choisi	Risque Résiduel	Accepté ?	Justification
Phishing	20/25 (critique)	Réduction du risque	4/25 (faible)	✓ Oui	MFA, SIEM, formations réduisent considérablement le risque.
Attaque DDoS	18/25 (élevé)	Partage du risque	6/25 (modéré)	✓ Oui	Cloudflare (solution externe cloud) atténue efficacement les attaques, risque résiduel maîtrisé.
Fraude interne	10/25 (modéré)	Maintien du risque	2/25 (faible)	✓ Oui	Risque accepté car compensé par audits réguliers et séparation des rôles.
Non-conformité RGPD	16/25 (élevé)	Refus du risque	0/25 (supprimé)	✓ Oui	Données supprimées, donc le risque est éliminé.

19/02/2026

Dr Maha Charfeddine

124

Traitement du risque

ISO/IEC 27001, article 6.1.3 (suite)

Résumé du traitement des risques chez FinSecure

Grâce à l'application de la **clause 6.1.3 de l'ISO 27001**, FinSecure renforce sa cybersécurité, assure la protection des clients et garantit la conformité réglementaire.

Étape	Application chez FinSecure
Choix des options de traitement	Réduction, partage, maintien ou refus des risques.
Détermination des mesures	Implémentation du SIEM, formation, filtrage anti-phishing.
Vérification avec l'Annexe A	Validation que toutes les mesures nécessaires sont bien appliquées.
Déclaration d'applicabilité	Documentation des mesures mises en place et des exclusions.
Plan de traitement des risques	Feuille de route pour la mise en place des protections.
Validation des risques résiduels	Vérification que les risques sont à un niveau acceptable.

19/02/2026

Dr Maha Charfeddine

125

Objectifs et plans pour les atteindre

ISO/IEC 27001, article 6.2

L'organisation doit établir, aux fonctions et niveaux concernés, des objectifs de sécurité de l'information.

Les objectifs de sécurité de l'information doivent :

- a) être cohérents avec la politique de sécurité de l'information;
- b) être mesurables (si possible);
- c) tenir compte des exigences applicables à la sécurité de l'information, et des résultats de l'appréciation et du traitement des risques;
- d) être surveillés;
- e) être communiqués
- f) être mis à jour quand cela est approprié;
- g) être disponible sous forme d'information documentée.



19/02/2026

Dr Maha Charfeddine

126

Objectifs et plans pour les atteindre

ISO/IEC 27001, article 6.2

Exemple d'objectif : **Réduire le risque de phishing de niveau critique à modéré en 6 mois**

Élément ISO 27001 – Article 6.2	Application concrète chez FinSecure
a) Cohérent avec la politique SSI	Oui, inscrit dans la stratégie globale de sécurité de l'information .
b) Mesurable	Réduction du score de risque de 20/25 (critique) à ≤ 6/25 (modéré).
c) Prend en compte l'analyse de risque	Oui, le phishing a été identifié comme menace prioritaire dans le traitement des risques .
d) Surveillé	Tests de simulation de phishing trimestriels , indicateurs SIEM.
e) Communiqué	Sensibilisation via newsletters internes, affichage sécurité, sessions RH .
f) Mis à jour si nécessaire	Revu annuellement ou après incident réel détecté.
g) Disponible sous forme documentée	Intégré au plan de traitement des risques et dans la Déclaration d'applicabilité.

19/02/2026

Dr Maha Charfeddine

127

Objectifs et plans pour les atteindre

ISO/IEC 27001, article 6.2

ISO/IEC 27001, article 6.2 Objectifs de sécurité de l'information et plans pour les atteindre (suite)

L'organisation doit conserver des informations documentées sur les objectifs liés à la sécurité de l'information.

Lorsqu'elle planifie la façon d'atteindre ses objectifs de sécurité de l'information, l'organisation doit déterminer :

- h) ce qui sera fait ;**
- i) les ressources qui seront nécessaires ;**
- j) qui sera responsable ;**
- k) les échéances ; et**
- l) la façon dont les résultats seront évalués.**

19/02/2026

Dr Maha Charfeddine

128

Objectifs et plans pour les atteindre

ISO/IEC 27001, article 6.2

Plan d'action – Réduction du risque de phishing

Ce qui sera fait	Ressources nécessaires	Responsable	Échéance	Évaluation des résultats
Déploiement de l'authentification multi-facteurs (MFA)	Solution MFA, équipe IT	Responsable IT	2 mois	Activation MFA pour 100 % des employés
Mise en place d'un système SIEM	Outil SIEM, analyste cybersécurité	RSSI	3 mois	Réduction du nombre de connexions suspectes non détectées de 30%
Lancement de campagnes de formation anti-phishing	Budget formation, plateforme e-learning, RH	DRH + RSSI	6 mois	>90 % de taux de participation + taux de clic < 5 % sur test phishing
Simulations trimestrielles de phishing	Outil de simulation, animateur cybersécurité	RSSI	Chaque 3 mois	Taux d'erreur utilisateur < 5 %

19/02/2026

Dr Maha Charfeddine

129

Planification des changements

ISO/IEC 27001, article 6.3

Lorsque l'organisation détermine qu'il est nécessaire d'apporter des changements au système de management de la sécurité de l'information, ces changements doivent être effectués de manière planifiée.



Lors de la planification des changements, l'organisme peut prendre en compte les aspects suivants, sans s'y limiter :

- a) L'objectif des changements et leurs conséquences potentielles.
- b) La disponibilité des ressources
- c) L'attribution ou la réattribution des responsabilités et des pouvoirs

19/02/2026

Dr Maha Charfeddine

130

Planification des changements

ISO/IEC 27001, article 6.3

Calendrier de déploiement planifié :

Semaine 1-2 : Choix de la solution MFA (Google Authenticator, Microsoft Auth, etc.)

Semaine 3-4 : Configuration technique + tests en environnement

Semaine 5-6 : Formation et support utilisateurs

Semaine 7 : Déploiement progressif par service

Semaine 10 : Bilan + corrections éventuelles

19/02/2026

Dr Maha Charfeddine

131

Planification des changements

ISO/IEC 27001, article 6.3

Exemple de planification de changement chez FinSecure

Changement envisagé : Passage de l'authentification simple à l'authentification multi-facteurs (MFA) pour tous les employés.

Élément	Application chez FinSecure
Objectif du changement (6.3 a)	Renforcer la protection des comptes internes pour réduire le risque de compromission par phishing.
Conséquences potentielles (6.3 a)	- Perturbation temporaire des connexions - Besoin d'accompagnement utilisateur - Risque d'erreurs de configuration ou blocage utilisateur
Disponibilité des ressources (6.3 b)	- Budget validé pour la solution MFA - Équipe IT formée - Support utilisateur (helpdesk renforcé pendant la transition)
Attribution des responsabilités (6.3 c)	- Responsable IT : mise en œuvre technique - RSSI : supervision sécurité - DRH : communication et accompagnement des utilisateurs

19/02/2026

Dr Maha Charfeddine

132

Support

ISO/IEC 27001, article 7



7.1 Ressources

L'organisme doit identifier et fournir les ressources nécessaires à l'implantation appropriée du SMSI.



7.2 Compétence

L'organisme doit s'assurer qu'il dispose du personnel compétent pour effectuer les tâches relatives au SMSI.



7.3 Sensibilisation

L'organisme doit veiller à ce que ses employés soient au courant de la politique de sécurité de l'information, de leur rôle dans le SMSI et des conséquences de non-conformité aux exigences du SMSI.



7.4 Communication

L'organisme doit établir, mettre en œuvre et maintenir des dispositions pour la communication avec les parties intéressées internes et externes pertinentes.



7.5 Informations documentées

Le SMSI de l'organisme doit inclure les informations documentées exigées par ISO/IEC 27001 et les enregistrements démontrant l'efficacité du SMSI.

19/02/2026

Dr Maha Charfeddine

133

Support

ISO/IEC 27001, article 7

Exemple d'application de l'article 7 chez FinSecure

Article	Exigence	Exemple concret chez FinSecure
7.1 Ressources	Identifier et fournir les ressources nécessaires	FinSecure alloue un budget annuel dédié à la cybersécurité , incluant les licences SIEM, MFA et outils anti-phishing.
7.2 Compétence	Garantir la compétence du personnel	Les nouveaux analystes sécurité suivent une formation interne sur le SMSI et les procédures anti-fraude dès leur embauche.
7.3 Sensibilisation	Sensibiliser les employés à la sécurité de l'information	Tous les collaborateurs participent à une session de sensibilisation au phishing tous les 6 mois , avec un test de validation.
7.4 Communication	Établir les mécanismes de communication interne/externe	Une newsletter cybersécurité est envoyée chaque mois aux employés ; le RSSI communique aussi avec les partenaires critiques lors d'incidents.
7.5 Informations documentées	Créer, mettre à jour et maîtriser les documents nécessaires au SMSI	Les politiques de sécurité, les plans de traitement des risques et les comptes-rendus d'audits sont enregistrés sur une plateforme documentaire sécurisée, avec contrôle des accès.

19/02/2026

Dr Maha Charfeddine

134

Fonctionnement

ISO/IEC 27001, article 8



8.1 Planification et contrôle opérationnels

L'organisme doit planifier, mettre en œuvre et contrôler les processus nécessaires à la satisfaction des exigences de la norme. L'organisme doit également mettre en œuvre des plans, conserver des informations documentées comme preuve de la mise en œuvre des processus planifiés, contrôler et revoir les changements planifiés, et déterminer et contrôler les processus externalisés.



8.2 Appréciation des risques de sécurité de l'information

L'organisme doit réaliser des appréciations des risques de sécurité de l'information à des intervalles planifiés et doit conserver des informations documentées sur les résultats de l'appréciation des risques.



8.3 Traitement des risques de sécurité de l'information

L'organisme doit mettre en œuvre le plan de traitement des risques de sécurité de l'information et doit conserver des informations documentées sur les résultats du traitement des risques.

19/02/2026

Dr Maha Charfeddine

135

Article 6 vs Article 8

Élément	Article 6 – Planification des actions	Article 8 – Mise en œuvre et évaluation des risques
Objectif	Définir quoi faire pour traiter les risques [planification]	Mettre en œuvre ce qui a été prévu et mesurer les résultats
Contenu principal	- Évaluation des risques - Options de traitement - Objectifs - Plans d'actions (6.1 / 6.2 / 6.3)	- Réalisation régulière de l'évaluation des risques (8.2) - Application des traitements décidés (8.3)
Exemple FinSecure Phishing	FinSecure prévoit : - MFA - Formations - SIEM → Planifié dans un plan de traitement sur 6 mois	FinSecure déploie : - La MFA est activée - Formations réalisées - Taux de clic analysé dans le SIEM
Sortie attendue	Objectifs définis Délai fixé Responsables désignés	Mesures effectivement mises en œuvre Risques résiduels évalués
Documentation associée	- Plan de traitement des risques - Déclaration d'applicabilité - Objectifs sécurité (6.2)	- Registre des risques mis à jour - Rapports d'évaluation - Résultats du traitement (preuve d'exécution)
Responsables typiques	RSSI + Direction + DRH	RSSI + équipe IT + responsables métiers

19/02/2026

Dr Maha Charfeddine

136

Fonctionnement

Application de l'article 8 – Appréciation et traitement des risques de sécurité de l'information chez FinSecure

Chapitre	Exigence ISO/IEC 27001	Exemple chez FinSecure
8.2 – Appréciation des risques de sécurité de l'information	- Réaliser des appréciations (analyses) de risques à intervalles réguliers ou lors de changements importants. - Conserver les résultats sous forme documentée.	- FinSecure réalise une évaluation complète des risques tous les 12 mois, ou en cas d'intégration d'un nouveau service (ex : paiement via crypto). - Les résultats sont documentés dans l'outil de gestion des risques (Risk Register), avec score, impact, probabilité, et priorisation.
8.3 – Traitement des risques de sécurité de l'information	- Mettre en œuvre le plan de traitement basé sur l'évaluation. - Documenter les résultats du traitement.	- Suite à l'analyse, FinSecure déploie des mesures correctives : SIEM, MFA, audits internes. - Les plans sont intégrés au plan de traitement des risques, avec échéances et responsables. - Les risques résiduels sont revus en comité de sécurité trimestriel.

19/02/2026

Dr Maha Charfeddine

137

Fonctionnement

Application de l'article 8 – Appréciation et traitement des risques de sécurité de l'information chez FinSecure

Exemples concrets d'informations documentées chez FinSecure (conformément à l'article 8)

- Rapport d'analyse des risques 2025 : Score initial, menaces identifiées (phishing, DDoS...), matrices d'impact/probabilité.
- Plan de traitement des risques : Mesures retenues (réduction, partage...), échéances, ressources et niveaux de risques résiduels.
- Compte-rendu de validation : Acceptation des risques résiduels critiques (phishing réduit à 4/25 par ex.).

19/02/2026

Dr Maha Charfeddine

138

Évaluation des performances

ISO/IEC 27001. article 9

Surveillance et revue du SMSI

Surveillance et revue des procédures de détection et de prévention des événements de sécurité

Revue régulière de l'efficacité du SMSI en intégrant les commentaires des parties intéressées.

Mesure de l'efficacité des processus et des mesures



Revue de l'appréciation et du traitement des risques

Réalisation d'audits internes

Revue de direction et mise à jour des plans de sécurité

19/02/2026

Dr Maha Charfeddine

139

Évaluation des performances

ISO/IEC 27001, article 9

9.1

Surveillance, mesures, analyse et évaluation

L'organisme doit évaluer la performance et l'efficacité du système de management de la sécurité des informations et conserver des informations documentées comme preuve des résultats de la surveillance et de la mesure.

9.2

Audit interne

L'organisme doit effectuer des audits internes à intervalles planifiés afin de valider si le système de management de la sécurité de l'information est effectivement mis en œuvre, maintenu et conforme aux exigences propres de l'organisme ainsi qu'aux exigences de la norme.

9.3

Revue de direction

La direction doit procéder à des revues du SMSI à des intervalles planifiés afin de s'assurer de son adéquation, de sa pertinence et de son efficacité. L'organisme doit conserver des informations documentées comme preuve des résultats de la revue de direction.

19/02/2026

Dr Maha Charfeddine

140

Évaluation des performances

ISO/IEC 27001, article 9

Audit interne du SMSI

ISO/IEC 27001, article 9.2.1

L'organisation doit réaliser des audits internes à des intervalles planifiés afin de recueillir des informations permettant de déterminer si le système de management de la sécurité de l'information :

a) est conforme :

- 1) aux exigences propres de l'organisation concernant son système de management de la sécurité de l'information;
- 2) aux exigences du présent document;

b) est efficacement mis en œuvre et tenu à jour.

Des activités régulières d'audit interne permettent l'évaluation continue de l'efficacité du SMSI et l'identification des opportunités d'amélioration.

19/02/2026

Dr Maha Charfeddine

141

Évaluation des performances

ISO/IEC 27001, article 9

Revue de direction

ISO/IEC 27001, articles 9.3.1 et 9.3.2

À des intervalles planifiés, la direction doit procéder à la revue du système de management de la sécurité de l'information mis en place par l'organisation, afin de s'assurer qu'il est toujours approprié, adapté et efficace.

La revue de direction doit prendre en compte :

- a) l'état d'avancement des actions décidées à l'issue des revues de direction précédentes;
- b) les modifications des enjeux externes et internes pertinents pour le système de management de la sécurité de l'information;
- c) l'évolution des besoins et des attentes des parties intéressées pertinentes pour le système de management de la sécurité de l'information;
- d) les retours sur les performances de sécurité de l'information, y compris les tendances concernant :
 - 1) les non-conformités et les actions correctives;
 - 2) les résultats de l'évaluation de la surveillance et des mesures;
 - 3) résultats d'audit;
 - 4) la réalisation des objectifs en matière de sécurité de l'information;
- e) les retours d'information des parties intéressées;
- f) les résultats de l'appréciation des risques et l'état d'avancement du plan de traitement des risques;
- g) les opportunités d'amélioration continue.

19/02/2026

Dr Maha Charfeddine

142

Évaluation des performances

ISO/IEC 27001, article 9

Chapitre	Exigence ISO/IEC 27001	Exemple concret chez FinSecure
9.1 Surveillance, mesure, analyse et évaluation	FinSecure doit déterminer quoi surveiller, comment, quand, par qui, et comment évaluer les résultats.	✓ Surveillance du taux de clics sur mails de phishing [via simulations trimestrielles] ✓ Méthode utilisée : outil de simulation + analyse SIEM ✓ Responsable : RSSI ✓ Évaluation des résultats : rapport présenté chaque trimestre au comité de cybersécurité
9.2 Programme d'audit interne	Planifier et exécuter des audits internes réguliers sur les processus du SMSI (en tenant compte des résultats précédents).	✓ Un audit interne du SMSI est réalisé chaque année en mars ✓ Objectivité assurée par un auditeur indépendant ✓ Portée : gestion des accès, conformité RGPD, réponse aux incidents ✓ Résultats communiqués à la direction et archivés dans le dossier "Audit-SMSI"
9.3.3 Résultats de la revue de direction	Organiser une revue de direction annuelle incluant les décisions d'amélioration et de changement, et conserver les preuves.	✓ FinSecure organise une revue annuelle du SMSI chaque décembre ✓ Participants : DG, RSSI, DRH, DPO ✓ Décisions prises : élargissement du périmètre de sécurité aux outils mobiles, renforcement de la formation phishing ✓ Rapport diffusé aux parties prenantes et conservé dans l'outil documentaire sécurisé

Informations documentées associées (preuves) chez FinSecure :

- Rapports trimestriels d'analyse SIEM, Rapports d'audit interne (avec grille de conformité)
- Compte-rendu de la revue de direction annuelle, Tableaux de bord des indicateurs de performance sécurité

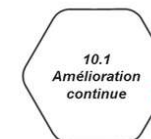
19/02/2026

Dr Maha Charfeddine

143

Amélioration

ISO/IEC 27001, article 10



10.1
Amélioration
continue

L'organisme doit veiller à l'amélioration continue de la pertinence, de l'adéquation et de l'efficacité du système de management de la sécurité des informations.



10.2 Non-
conformité et
actions
correctives

L'organisme doit prendre les mesures appropriées lorsqu'une non-conformité se produit. Il doit évaluer et mettre en œuvre ces actions, examiner leur efficacité et, si nécessaire, apporter des modifications au SMSI. L'organisme doit également conserver des informations documentées comme preuve des résultats des actions correctives.

19/02/2026

Dr Maha Charfeddine

144

Amélioration continue

ISO/IEC 27001, article 10.1

L'organisation doit continuellement améliorer la pertinence, l'adéquation et l'efficacité du système de management de la sécurité de l'information.

L'amélioration continue est le processus visant à augmenter l'efficacité et l'efficience de l'organisme à répondre à sa politique et à ses objectifs.

L'amélioration continue est obtenue en fixant des objectifs de performance organisationnelle, en mesurant et révisant, et en apportant les changements nécessaires aux processus, systèmes, ressources, etc.

19/02/2026

Dr Maha Charfeddine

145

Traitement des non-conformités

ISO/IEC 27001, article 10.2

Lorsqu'une non-conformité se produit, l'organisation doit :

- a) réagir à la non-conformité, et le cas échéant :
 - 1) agir pour la maîtriser et la corriger;
 - 2) traiter les conséquences;
- b) évaluer s'il est nécessaire de mener une action pour éliminer les causes de la non-conformité, de sorte qu'elle ne se reproduise plus, ou qu'elle ne se produise pas ailleurs. À cet effet, l'organisation :
 - 1) examine la non-conformité;
 - 2) détermine les causes de non-conformité; et
 - 3) détermine si des non-conformités similaires existent, ou pourraient se produire;
- c) mettre en œuvre toutes les actions requises;
- d) réviser l'efficacité de toute action corrective mise en œuvre; et
- e) modifier, si nécessaire, le système de management de sécurité de l'information.

Les actions correctives doivent être à la mesure des effets des non-conformités rencontrées.



Maintien des informations documentées

ISO/IEC 27001, article 10.2

Des informations documentées doivent être disponibles comme preuve:

- f) de la nature des non-conformités et de toute action subséquente;
- g) des résultats de toute action corrective.



19/02/2026

Dr Maha Charfeddine

146

Amélioration continue

ISO/IEC 27001, article 10.1

Chapitre	Exemple concret chez FinSecure
10.1 Amélioration continue	✓ Après la revue de direction annuelle, FinSecure décide d'élargir la formation de sensibilisation au phishing à tous les prestataires externes ayant accès au réseau interne. ✓ Mise en place d'un tableau de bord dynamique de suivi des incidents pour détecter les tendances et améliorer la réactivité.
10.2 Non-conformité et action corrective	✓ Lors d'un audit interne, une non-conformité a été détectée : mauvais archivage de certains logs SIEM. ✓ Actions prises : archivage corrigé, procédure mise à jour, formation rapide de l'équipe IT ✓ Une vérification de l'efficacité a été réalisée 1 mois plus tard = conforme

Informations documentées chez FinSecure :

- Tableau de suivi des actions d'amélioration, Actes de la revue de direction mentionnant les décisions d'amélioration
- Fiche de non-conformité avec plan d'action correctif, Rapport de vérification post-action

19/02/2026

Dr Maha Charfeddine

147

Quiz & Exercice Maîtriser la norme ISO 27001-2022

19/02/2026

Dr Maha Charfeddine

148